

Stratégie de Cybersécurité

d'un opérateur industriel critique

Elipe Ops est un opérateur régional de distribution d'électricité basé à Grenoble, couvrant les départements 38, 73 et 74. L'organisation exploite une infrastructure mixte IT bureautique et OT industrielle (SCADA) et est classée Opérateur d'Importance Vitale.

Format de l'épreuve

Soutenance orale · 30 minutes + 10 min Q&R · Jury composé de 2 professionnels externes

Chiffres clés

320

employés

4

sites opérationnels

OIV

classé LPM

IT + OT

SCADA Schneider

Sommaire

01	Présentation de l'organisation Contexte métier · Organigramme · Parties prenantes	06	Analyse des risques — EBIOS RM 5 ateliers · Matrice 5x5 · Scénario fil rouge	ÉLIM.	
02	Cartographie 4 sites · Protocoles · VPN · Cloud Microsoft 365	ÉLIM.	07	Politique de sécurité (PSSI) Zero Trust IT · IEC 62443 OT · Objectifs CIA+D	ÉLIM.
03	Cartographie en module purdu Modèle Purdue · Zones IEC 62443 · Protocoles industriels	ÉLIM.	08	Plan d'actions · PCA · Sensibilisation Budget · Planning · Corpus documentaire · Formation	
04	Frontière IT/OT et scénario de pivot Vecteur d'attaque · Contraintes OT · Architecture cible		09	Conclusion Synthèse · Points différenciants · Perspectives	
05	Rapport de veille Menaces OT · Réglementations NIS2, LPM, IEC 62443 · Sources	ÉLIM.			

⚠ Les éléments marqués ÉLIM. correspondent à des compétences éliminatoires : leur non-acquisition invalide l'ensemble du bloc.

Bloc 1 : Couverture des compétences évaluées

Toutes les compétences du Bloc 1 sont couvertes dans ce support — les compétences éliminatoires sont signalées 

Compétence	Code RNCP	Sujet traité	Livrable	Slides
Analyse de l'organisation	B1.A1.C1	Présentation Elipse Ops organigramme, parties prenantes, dépendances critiques	Support oral	Slide 3
Cartographie du SI	B1.A1.C2	Réseau IT (4 sites, VPN, cloud) + Réseau OT (Purdue, IEC 62443, protocoles industriels)	Schémas IT + OT	Slides 4–5
Veille cyber et réglementaire	B1.A1.C3	4 menaces OT (Industroyer2, APT, pivot, supply chain) + cadre NIS2, LPM, IEC 62443, ISO 27001	Rapport de veille	Slides 7–8
Analyse des risques	B1.A1.C4	EBIOS RM — 5 ateliers — 5 risques dont 3 critiques — scénario R2 pivot IT→OT détaillé	Matrice 5x5	Slide 9
Définition de la PSSI	B1.A2.C1	Objectifs CIA+D — Zero Trust IT — IEC 62443 SL2 OT — 6 référentiels (NIS2, LPM, ISO 27001...)	Note de cadrage	Slide 10
Gap Analysis & plan d'actions	B1.A2.C2 B1.A2.C3	6 écarts identifiés — 6 actions prioritaires — budget 173 k€ — planning M+1 → M+6	Plan d'actions	Slide 11
Plans de résilience	B1.A3.C2	PCA — 4 scénarios — RTO 2h SCADA justifié — RPO 1h — tests semestriels	PCA / PRA	Slide 12
Corpus doc. & sensibilisation	B1.A3.C1 B1.A3.C3	6 documents clés IT+OT — 5 profils utilisateurs — indicateurs mesurables — conformité RGAA	Plan formation	Slide 13

Présentation d’Elipe Ops

Opérateur régional de distribution d'électricité

Elipe Ops est une filiale d'un groupe énergétique national, implantée à Grenoble et couvrant trois départements alpins (Isère, Savoie, Haute-Savoie). L'organisation assure la distribution d'électricité à environ 180 000 foyers et entreprises sur son territoire de concession.

320

Employés répartis sur 4 sites

180 k

Foyers et entreprises alimentés

2,8 M€

Budget IT annuel

OIV

Classé LPM — secteur énergie

Implantation géographique

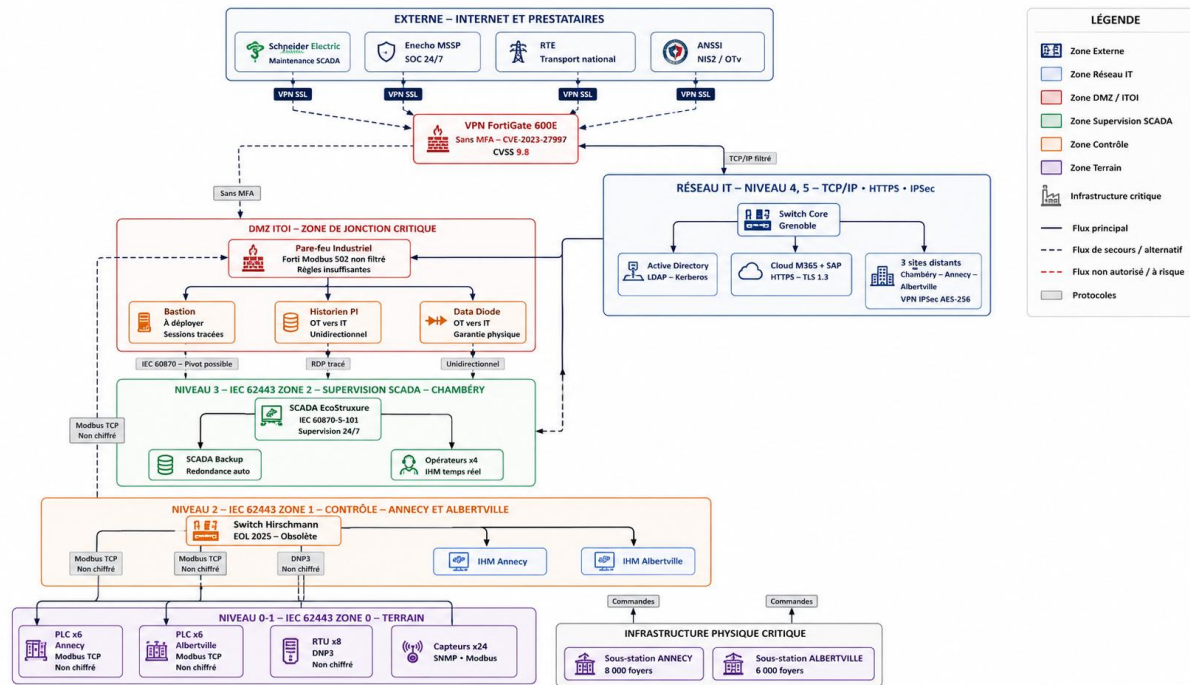
Grenoble	Siège administratif · DSI · Direction · 120 pers.
Chambéry	Centre de conduite réseau SCADA 24/7 · 60 pers.
Annecy	Sous-station principale · Automates PLC · 70 pers.
Albertville	Sous-station principale · Automates PLC · 70 pers.

Principales parties prenantes externes

- ANSSI — autorité de contrôle NIS2 / OIV, notifications obligatoires
- Schneider Electric — éditeur SCADA, accès maintenance distante
- TechCo (MSSP) — SOC externalisé 24/7, infogérance partielle
- RTE — réseau de transport national, interdépendance opérationnelle

Cartographie

Protocoles : TCP/IP · HTTPS / TLS 1.3 · LDAP · Kerberos · SMBv3 · IPSec · Protocoles industriels non chiffrés Norme IEC 62443



Protocoles internes : LDAP / Kerberos (authentification AD) · SMBv3 (partages) · IPSec AES-256 (VPN inter-sites) · HTTPS / TLS 1.3 (cloud)

→ Interface vers DMZ IT/OT : le VPN FortiGate est le point d'entrée unique pour les prestataires — vecteur d'attaque principal identifié dans l'analyse des risques.

Modèle Purdue

Zones et conduits

Niv. 4-5 IT	Réseau bureautique — AD, SAP, M365, VPN FortiGate
DMZ OT	Zone de jonction — Firewall industriel · Historien PI · Bastion · Data Diode
Niv. 3 Zone 2	Supervision SCADA — EcoStruxure Schneider · Srv backup · 4 postes opérateurs
Niv. 2 Zone 1	Contrôle — Switch Hirschmann (⚠ EOL 2025) · IHM Annecy & Albertville
Niv. 1-0 Zone 0	Terrain — PLC Modicon M340 ×12 (Modbus TCP ⚠) · RTU SEL-351 ×8 (DNP3 ⚠) · ION Meters ×24 (SNMP)

⚠ Protocoles industriels non chiffrés nativement :

Modbus TCP — aucune authentification, aucun chiffrement, rejouable · DNP3 — pas de chiffrement natif · OPC-UA — chiffrement disponible mais non activé

Frontière IT/OT — Comment le pivot devient possible

Analyse du scénario d'incident fil rouge — vecteur CVE-2023-27997 FortiGate (CVSS 9.8)

Chaîne d'attaque — état actuel vulnérable

1

Phishing ciblé → compte Schneider compromis

L'attaquant usurpe l'identité d'un technicien de maintenance.

2

Exploitation CVE-2023-27997 sur FortiGate

Exécution de code à distance sans authentification — accès au réseau IT.

3

Traversée de la DMZ mal configurée

Port Modbus 502 accessible depuis le serveur de supervision — aucun filtrage strict.

4

Injection de commandes Modbus falsifiées

Via le SCADA compromis, envoi de consignes erronées aux PLC d'Annecy.

5

Impact physique — 8 000 foyers coupés 4h

Surcharge transformateurs → coupure préventive → obligation NIS2 : notification ANSSI < 24h.

Contraintes spécifiques OT

Disponibilité avant tout

Un arrêt SCADA = coupure physique immédiate. La confidentialité est secondaire.

Pas de patch à chaud

Les automates tournent 24/7. Toute mise à jour exige une fenêtre de maintenance planifiée.

Protocoles hérités

Modbus et DNP3 ont été conçus pour la fiabilité, pas pour la sécurité. Aucun chiffrement natif.

Impact physique réel

Une commande falsifiée peut provoquer un court-circuit, un incendie, ou une coupure en cascade.

Architecture cible — mesures correctives

MFA obligatoire sur tous les accès VPN prestataires (Action P1 — M+1)

Refonte DMZ avec filtrage strict Modbus/DNP3 et whitelist IP (Action P2 — M+2)

Data Diode déployée : flux OT→IT unidirectionnel physiquement garanti

Bastion hôte OT : sessions enregistrées, moindre privilège, révocation immédiate

Menaces cyber identifiées — Secteur énergie / OT

Sources : ANSSI cert.ssi.gouv.fr · ENISA Threat Landscape 2024 · Dragos ICS Report 2024 · CERT-FR · CISA ICS-CERT

Méthodologie :

Flux RSS CERT-FR · Bulletins ANSSI mensuels · Rapports Dragos OT · ENISA Threat Landscape · ICS-CERT Advisories · CESIN · Conférences RSSI

CRITIQUE	Ransomware sur OT — Industroyer2, CI0p Source : Dragos 2024 · ENISA Chiffrement du SCADA avec arrêt total de la supervision — impact distribution immédiat. Industroyer2 (Ukraine 2022) a directement manipulé des RTU pour déclencher des coupures électriques. Ce vecteur est directement applicable au contexte Elipe.
CRITIQUE	Pivot IT→OT via compte prestataire compromis Source : CERT-FR · CISA Compromission du VPN FortiGate (CVE-2023-27997, CVSS 9.8) → traversée DMZ → accès SCADA → manipulation automates. C'est le scénario fil rouge retenu pour ce projet — vecteur le plus probable pour Elipe compte tenu des lacunes actuelles.
ÉLEVÉ	APT étatiques — Sandworm, APT28 Source : Mandiant · ANSSI TLP:WHITE Groupes parrainés par des États ciblant les OIV énergie européens pour l'espionnage et le sabotage. Durée moyenne de présence réseau avant détection : 6 à 18 mois. Particularité : les APT exploitent les accès légitimes (prestataires) pour éviter la détection.
ÉLEVÉ	Compromission supply chain — éditeur SCADA Source : ENISA · CISA Mise à jour malveillante ou accès maintenance détourné chez Schneider Electric → propagation directe via le canal de confiance habituel. Risque amplifié par l'absence actuelle de vérification d'intégrité des mises à jour SCADA chez Elipe.

Réglementations et normes applicables à Elipe Ops

Obligations légales en tant qu'OIV entité essentielle NIS2

NIS2

Directive UE 2022/2555 Entité Essentielle

Notification à l'ANSSI sous 24h pour tout incident significatif, rapport complet sous 72h

Mesures de sécurité proportionnées : gestion des risques, continuité, sécurité de la supply chain

Audit de sécurité obligatoire par l'ANSSI pour les entités essentielles du secteur énergie

Responsabilité personnelle des dirigeants en cas de non-conformité avérée

LPM / OIV

Loi de Programmation Militaire Opérateur d'Importance Vitale

Protection obligatoire des Systèmes d'Information d'Importance Vitale (SIIV)

Contrôle annuel de l'ANSSI sur les mesures de sécurité IT et OT

Règles sectorielles spécifiques définies par arrêté ministériel (secteur énergie)

Obligation de déclarer et de protéger les accès aux systèmes critiques

IEC 62443

Standard international Cybersécurité des systèmes industriels

Cible : Security Level 2 (SL2) pour les zones SCADA et automates principaux

Principe des zones et conduits : segmentation du réseau OT par niveau de criticité

Organisation en zones : terrain (Z0) → contrôle (Z1) → supervision (Z2) → DMZ → IT

Exigences sur la traçabilité des opérations OT et la gestion des accès prestataires

ISO 27001

Système de Management de la Sécurité de l'Information

Cadre SMSI aligné sur les exigences NIS2 processus d'amélioration continue

Certification visée à horizon 24 mois, intégrée à la feuille de route sécurité

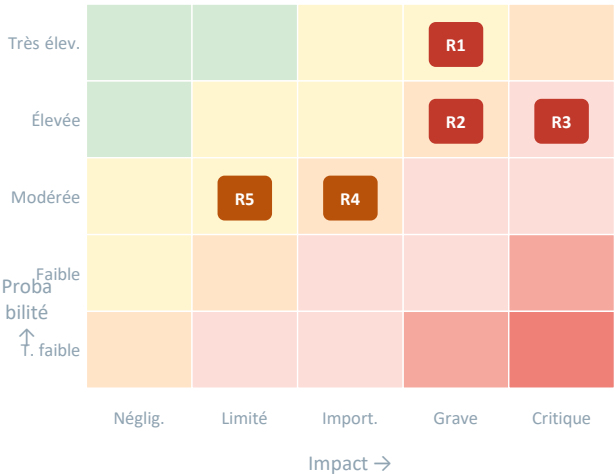
Compatible avec IEC 62443 pour le périmètre OT approche unifiée IT + OT

Gestion documentaire, contrôle d'accès, cryptographie, continuité d'activité

Analyse EBIOS RM — Cartographie des risques

Méthode ANSSI · 5 ateliers · Obligatoire pour les OIV/NIS2 · Conforme contexte industriel IT+OT

Pourquoi EBIOS RM : Méthode officielle ANSSI · Reconnue par les auditeurs LPM et NIS2 · Intègre les sources de risque étatiques · Adaptée aux contextes IT+OT



Risques identifiés

ID	Risque	Criticité	Traitement
R1	Ransomware sur réseau OT	CRITIQUE	Réduction
R2	Pivot IT→OT (fil rouge Bloc 4)	CRITIQUE	Réduction
R3	APT étatique sur SCADA	CRITIQUE	Réduction
R4	Supply chain éditeur SCADA	ÉLEVÉ	Transfert
R5	DoS sur serveur de supervision	ÉLEVÉ	Réduction

Politique de Sécurité du SI (PSSI) Note de cadrage

Double périmètre IT + OT · Alignée NIS2, LPM, IEC 62443 · Valable 3 ans (2025–2028)

Objectifs de sécurité: périmètre IT + OT + DMZ + accès prestataires

Disponibilité	PRIORITAIRE	SLA 99,9 % sur la supervision réseau, RTO 2h SCADA, coupure = impact physique immédiat sur 180 k foyers
Intégrité	CRITIQUE	Exactitude des consignes automates, 0 modification non autorisée sur le réseau OT
Confidentialité	IMPORTANT	Plans réseau, données clients, données d'exploitation.
Traçabilité	REQUIS	Audit trail 100 % des accès OT, rétention 12 mois, conformité LPM

Modèles de sécurité retenus

Zero Trust (réseau IT)

Vérification systématique · MFA · Conditional Access Azure AD · Microsegmentation · Moindre privilège

IEC 62443 SL2 (réseau OT)

Zones et conduits · Séparation IT/OT · Bastion hôte · Traçabilité complète des accès OT

Référentiels intégrés à la PSSI

NIS2 — entité essentielle, obligations de reporting

LPM / OIV — SIIV, contrôle ANSSI annuel

IEC 62443 — cible SL2 pour les zones OT critiques

ISO 27001 — SMSI certifiable, horizon 24 mois

Écarts identifiés et feuille de route sécurité

6 actions prioritaires · Budget 173 k€ · Planning M+1 → M+6 · Impact arrêt SCADA : 45 k€/heure

Principaux écarts identifiés

CRITIQUE	Absence de MFA sur VPN prestataires CVE-2023-27997 — vecteur d'attaque principal non corrigé
CRITIQUE	DMZ IT/OT insuffisamment segmentée Port Modbus 502 accessible depuis le réseau IT
ÉLEVÉ	Aucun RSSI OT dédié en interne Zéro expert sécurité industrielle — non conforme LPM
ÉLEVÉ	SIEM OT absent Aucune détection comportementale — MTDD non maîtrisé
MOYEN	Firmware automates — dernière MAJ 2019 CVE non patchées, switch Hirschmann EOL 2025

Plan d'actions priorisé

P1	MFA obligatoire VPN prestataires M+1 · FortiGate + Azure AD	8 k€
P2	Refonte DMZ — zones IEC 62443 M+2 · Firewall industriel	45 k€
P3	Recrutement RSSI OT M+1 · Expert ICS certifié	12 k€/mois
P4	SIEM OT — Claroty (sondes passives) M+3 · Monitoring réseau OT	80 k€
P5	Chiffrement flux supervision (TLS 1.3) M+4 · Passerelle OT→IT	15 k€
P6	MAJ firmware automates planifiée M+6 · Fenêtres maintenance	25 k€

Budget total estimé :

173 k€ + 12 k€/mois

Impact arrêt SCADA : ~45 k€/heure · Obligation NIS2 : notification ANSSI < 24h

Plan de Continuité d'Activité — Résilience du SI

4 scénarios couverts · RTO/RPO définis · Tests semestriels · Impact écologique évalué

Scénarios de crise couverts

- Compromission du SCADA et manipulation des consignes automates: risque de surcharge ou coupure involontaire
- Perte du centre de conduite réseau de Chambéry: bascule sur site de repli (Grenoble siège)
- Attaque ransomware chiffrant le SI IT: impact sur la gestion opérationnelle et les outils bureautiques
- Coupure d'une sous-station principale (Annecy ou Albertville) suite à incident physique ou cyber

Indicateurs de continuité (RTO / RPO)

Système / Service	RTO cible	RPO cible	Justification
Supervision SCADA	2 heures	1 heure	Priorité absolue: toute indisponibilité = coupure physique
Centre de conduite (Chambéry)	4 heures	1 heure	Bascule sur site de repli: procédure testée
SI IT (messagerie, ERP)	8 heures	4 heures	Impact indirect: tolérance opérationnelle plus élevée
Données facturation clients	24 heures	24 heures	Impact commercial: acceptable pour la continuité du service

Tests :	Exercice sur table semestriel · Simulation bascule Chambéry · Test restauration SCADA depuis sauvegarde hors-ligne · Impact écologique des systèmes de secours : +35 % consommation compensé par certificats EnR.
---------	---

Plan de sensibilisation et de formation à la sécurité

5 profils utilisateurs · Formations adaptées IT et OT · Indicateurs d'évaluation · Conformité RGAA

Le facteur humain reste le premier vecteur d'entrée dans les incidents cyber. Chez Elipe Ops, la sensibilisation couvre deux populations très différentes : les utilisateurs IT classiques et les opérateurs OT dont les actes ont des conséquences physiques immédiates. Le programme est structuré par profil, avec des contenus et des fréquences adaptés.

1	Opérateurs SCADA	Risques :	Ingénierie sociale ciblée · Manipulation de consignes · Faux ordres de maintenance	Indicateurs :	Taux de clics phishing : objectif < 5 %
	Mensuelle	Contenu :	Simulation d'anomalies SCADA · Procédures de signalement · Gestion de crise OT		
2	Techniciens terrain	Risques :	Accès physique non contrôlé aux automates · Shadow IT · Clés USB inconnues	Indicateurs :	Score quiz e-learning : objectif > 80 %
	Trimestrielle	Contenu :	Sécurité physique OT · Procédures d'accès et d'intervention · Signalement incidents		
3	Équipe IT / DSI	Risques :	Phishing avancé · Gestion des accès prestataires · Dérive des droits d'accès	Indicateurs :	Délai de signalement incidents : < 2h
	Mensuelle	Contenu :	Exercices phishing Knowbe4 · Gestion IAM · SecNumAcadémie ANSSI · Veille CVE		
4	Direction / Managers	Risques :	Fraude au président · Prise de décision sous pression · Obligations NIS2 / LPM	Indicateurs :	Participation exercices : 100 %
	Semestrielle	Contenu :	Exercice tabletop COMEX · Responsabilités juridiques · Simulation crise médiatique		
5	Prestataires externes	Risques :	Accès distants non sécurisés · Non-respect des procédures · Exfiltration involontaire	Indicateurs :	Signalements spontanés : en hausse
	Avant chaque mission	Contenu :	Charte sécurité prestataires · MFA obligatoire · Traçabilité accès · Confidentialité		

Accessibilité : supports conformes RGAA · sous-titrage vidéos · format FALC pour techniciens terrain · plateforme Knowbe4 compatible lecteur d'écran

Synthèse — Bloc 1

Ce que démontre ce dossier

Une organisation fictive crédible et réaliste

Elipse Ops offre un contexte IT + OT suffisamment riche pour couvrir l'ensemble des 8 livrables du Bloc 1, avec une double complexité réglementaire (NIS2, LPM, IEC 62443) et un scénario d'incident directement inspiré de cas réels.

Une cartographie rigoureuse du système d'information

Double schéma (Purdue + zones IEC 62443) documentant la frontière IT/OT, les protocoles industriels non chiffrés, et le vecteur de pivot qui sera le fil rouge du Bloc 4 (CVE-2023-27997, CVSS 9.8).

Une analyse des risques EBIOS RM construite sur le contexte industriel

5 ateliers, 5 risques identifiés dont 3 critiques, avec le scénario R2 (pivot IT→OT) documenté en détail — directement issu de la cartographie et aligné sur les menaces réelles du secteur énergie.

Une PSSI cohérente qui distingue IT et OT

Zero Trust pour le réseau IT (MFA, Azure AD, microsegmentation) et IEC 62443 SL2 pour le réseau OT (zones, conduits, bastion hôte) — deux approches différentes pour deux types de réseaux aux contraintes opposées.

Un plan d'actions chiffré et un dispositif de résilience documenté

6 actions prioritaires (173 k€, M+1→M+6), PCA avec RTO 2h justifié, plan de sensibilisation sur 5 profils avec indicateurs mesurables — l'ensemble forme un dossier cohérent et actionnable.

Merci pour votre attention.

Questions ?

RNCP 40897

Expert en Cybersécurité

Jury

2 membres externes

Bloc 1

Soutenance orale 30'

Organisation

Elipse Ops

RNCP 40897 — EXPERT EN CYBERSÉCURITÉ

Bloc 2 — Piloter le cycle de conception, d'intégration et d'évaluation de solutions de sécurité

Intégration d'une solution de

Monitoring et de détection des menaces OT

Au sein du SI industriel d'Elip Ops

Solution déployée : Claroty Continuous Threat Detection (CTD)

Organisation : Elip Ops Opérateur d'Importance Vitale

Contents

Correspondance des compétences.....	4
1. Contexte et rappel de la stratégie de sécurité.....	5
1.1 Rappel de l'organisation Elipse Ops.....	5
1.2 Rappel du risque principal identifié au Bloc 1	5
1.3 La solution retenue : Claroty.....	5
Pourquoi Claroty plutôt qu'une autre solution.....	6
2. Spécifications techniques et fonctionnelles	7
2.1 Objectifs fonctionnels	7
2.2 Objectifs techniques	7
2.3 Critères d'acceptation	8
Annexe technique — Les protocoles industriels surveillés.....	9
Modbus TCP	9
DNP3	9
IEC 60870-5-101	9
Synthèse comparative.....	10
3. Organisation du projet d'intégration	11
3.1 Méthodologie de gestion de projet	11
3.2 Phases du projet	11
3.3 Planning — Diagramme de Gantt	12
3.4 Répartition des ressources.....	12
3.5 Budget prévisionnel	13
3.6 Critères de performance du projet	13
4. Rapport d'intégration et pilotage de l'avancement.....	14
4.1 Tableau de bord de suivi des tâches.....	14
4.2 Tableau des indicateurs clés de performance (KPI).....	14
4.3 Coordination des parties prenantes	15
4.4 Ajustements réalisés en cours de projet.....	15
5. Conception de l'architecture sécurisée	16
5.1 Architecture initiale et ses vulnérabilités	16
5.2 Architecture sécurisée cible.....	17
5.3 Comparaison avant / après.....	18
6. Gestion des identités et contrôle des accès	19
6.1 Authentification multifacteur (MFA)	19
6.2 Gestion des autorisations (RBAC)	19

6.3 Le bastion hôte pour les accès OT	20
6.4 Cycle de vie des identités.....	20
7. Déploiement d'une solution cryptographique.....	21
7.1 Cas d'usage : chiffrement des flux de supervision	21
7.2 Solution mise en place : TLS 1.3.....	21
7.3 Gestion des certificats (PKI interne)	22
8. Plan d'audit technique	23
8.1 Objectifs de l'audit	23
8.2 Périmètre de l'audit	23
8.3 Référentiels applicables	23
8.4 Critères d'évaluation	23
8.5 Méthodologie et planning de l'audit	24
9. Rapport d'audit technique	25
9.1 Méthodologie suivie	25
9.2 Synthèse des résultats	25
9.3 Observations détaillées.....	25
9.4 Conclusion de l'audit.....	26
Étude de cas — Détection du scénario de pivot par Claroty	27
Rappel du scénario d'attaque	27
Détection étape par étape.....	27
Chaîne de réaction déclenchée.....	27
10. Suivi des actions correctives	29
10.1 Plan de suivi des actions correctives.....	29
10.2 Évaluation de la réduction des risques	29
10.3 Conclusion générale.....	29
10.4 Retour d'expérience et prise de recul.....	30
Difficultés rencontrées.....	30
Arbitrages réalisés.....	30
Limites de la solution	30
Évolutions envisagées à moyen terme	30
Annexe A — Preuves de réalisation (captures d'écran).....	33
A.1 Inventaire automatique des équipements OT.....	33
A.2 Détection et alertes comportementales	33
A.3 Corrélation IT/OT dans Microsoft Sentinel.....	34
Glossaire.....	35

Références et sources	36
-----------------------------	----

Correspondance des compétences

Ce dossier couvre l'intégralité des compétences du Bloc 2. Les compétences éliminatoires sont signalées en rouge. Le tableau ci-dessous permet d'identifier rapidement où chaque compétence est traitée.

Compétence	Intitulé	Section	Statut
B2.A1.C1	Spécifications techniques et fonctionnelles	§2	Standard
B2.A1.C2	Organisation du projet d'intégration	§3	ÉLIMINATOIRE
B2.A1.C3	Pilotage de l'avancement du projet	§4	ÉLIMINATOIRE
B2.A2.C1	Conception d'une architecture sécurisée	§5	Standard
B2.A2.C2	Gestion des identités et contrôle des accès	§6	Standard
B2.A2.C3	Déploiement de solutions cryptographiques	§7	Standard
B2.A3.C1	Organisation d'un audit technique	§8	Standard
B2.A3.C2	Rédaction d'un rapport d'audit technique	§9	ÉLIMINATOIRE
B2.A3.C3	Suivi des actions correctives	§10	Standard

1. Contexte et rappel de la stratégie de sécurité

1.1 Rappel de l'organisation Elip Ops

Elip Ops est un opérateur régional de distribution d'électricité basé à Grenoble, couvrant les départements de l'Isère, de la Savoie et de la Haute-Savoie. L'organisation alimente environ 180 000 foyers et entreprises, emploie 320 personnes réparties sur quatre sites, et exploite une infrastructure mixte composée d'un réseau informatique de gestion (IT) et d'un réseau industriel de supervision et de contrôle (OT). En raison de son rôle dans l'approvisionnement électrique régional, Elip Ops est classée Opérateur d'Importance Vitale (OIV) et constitue une entité essentielle au sens de la directive NIS2.

Ce dossier s'inscrit dans la continuité directe du Bloc 1, qui a établi la stratégie globale de cybersécurité de l'organisation : cartographie du système d'information, analyse des risques selon la méthode EBIOS RM, politique de sécurité (PSSI), et plan d'actions priorisé. Le présent Bloc 2 sélectionne l'une des actions de ce plan et en pilote la mise en œuvre concrète, depuis la spécification jusqu'à l'audit de la solution déployée.

1.2 Rappel du risque principal identifié au Bloc 1

L'analyse de risques EBIOS RM conduite au Bloc 1 a identifié cinq risques majeurs, dont trois critiques. Le risque le plus structurant, désigné R2, concerne le pivot d'un attaquant depuis le réseau IT vers le réseau OT industriel. Ce scénario se déroule en cinq étapes : compromission d'un compte prestataire par hameçonnage, exploitation d'une vulnérabilité sur le concentrateur VPN, traversée d'une zone démilitarisée (DMZ) insuffisamment filtrée, accès au système de supervision SCADA, puis injection de commandes falsifiées vers les automates industriels provoquant une coupure électrique physique.

Ce scénario présente une caractéristique préoccupante : une fois l'attaquant présent sur le réseau OT, aucun dispositif n'est aujourd'hui en mesure de détecter son activité. Le réseau industriel d'Elip Ops fonctionne sans aucune surveillance comportementale. Les protocoles industriels utilisés — Modbus TCP, DNP3 — ne disposent d'aucun mécanisme d'authentification natif, et aucun outil ne contrôle la légitimité des commandes échangées entre le SCADA et les automates.

COMPRENDRE — Pourquoi ce manque de visibilité est le vrai problème

Sur un réseau IT classique, des outils comme un antivirus, un EDR ou un pare-feu détectent les comportements suspects. Sur le réseau OT d'Elip, rien de tel n'existe aujourd'hui. C'est l'équivalent d'une usine sans caméra de surveillance : si quelqu'un entre et manipule les machines, personne ne le voit. C'est précisément ce vide que la solution Claroty vient combler — elle apporte la surveillance qui manque sur le réseau industriel.

1.3 La solution retenue : Claroty

Pour répondre à ce manque de visibilité et de détection sur le réseau OT, le plan d'actions du Bloc 1 prévoyait le déploiement d'une solution de surveillance industrielle (action P4). La solution retenue est Claroty Continuous Threat Detection (CTD), une plateforme spécialisée dans la détection des menaces sur les réseaux industriels.

COMPRENDRE — Qu'est-ce que Claroty, concrètement ?

Claroty est un logiciel qui surveille en permanence tout ce qui circule sur le réseau industriel. Il fonctionne grâce à des « sondes » — des équipements qui écoutent le trafic réseau sans jamais y intervenir. La sonde observe quels automates communiquent entre eux, quelles commandes sont envoyées, et à quelle fréquence. Elle apprend ce qui est « normal » sur le réseau, puis alerte dès qu'un comportement anormal apparaît — par exemple une commande Modbus envoyée par un équipement qui n'en envoie jamais habituellement. C'est exactement ce qui permettrait de détecter l'étape finale du scénario de pivot identifié au Bloc 1.

Pourquoi Claroty plutôt qu'une autre solution

Trois solutions principales dominent le marché de la cybersécurité industrielle : Claroty, Dragos et Nozomi Networks. Le choix de Claroty pour Elip Ops repose sur des critères objectifs détaillés ci-dessous.

Critère	Claroty	Dragos	Nozomi
Sondes passives (sans impact OT)	Oui	Oui	Oui
Couverture Modbus / DNP3 / IEC 60870	Native et complète	Native	Native
Intégration Microsoft Sentinel		Partielle	Partielle
Positionnement / coût	Adapté ETI	Grands comptes	Adapté ETI
Cohérence écosystème Elipse	Forte (déjà Microsoft)	Faible	Moyenne

Elipse Ops utilise déjà l'écosystème Microsoft (Active Directory, Microsoft 365, et le SIEM Microsoft Sentinel prévu au Bloc 1). Claroty s'intègre nativement avec Sentinel, ce qui permet de centraliser les alertes IT et OT dans un seul outil de supervision. Cette cohérence architecturale réduit les coûts d'intégration et la complexité opérationnelle — un facteur déterminant pour une ETI régionale dont le budget IT annuel est de 2,8 M€.

💡 COMPRENDRE — Le mot « SIEM » expliqué simplement

Un SIEM (Security Information and Event Management) est un outil qui collecte les alertes de sécurité de toute l'organisation et les affiche dans un tableau de bord unique. Microsoft Sentinel est le SIEM d'Elipse côté IT. L'intérêt d'intégrer Claroty à Sentinel est de pouvoir corréler une alerte IT (par exemple une connexion VPN suspecte) avec une alerte OT (par exemple une commande Modbus anormale) au même endroit. Sans cette corrélation, le pivot IT vers OT resterait invisible car les deux moitiés de l'attaque seraient surveillées séparément.

2. Spécifications techniques et fonctionnelles

Compétence couverte : B2.A1.C1 — Rédiger les spécifications techniques et fonctionnelles de la solution de sécurité.

Les spécifications définissent ce que la solution Claroty doit accomplir, en termes fonctionnels (ce qu'elle fait pour l'organisation) et techniques (comment elle le fait). Elles sont directement alignées sur les exigences de la PSSI établie au Bloc 1.

COMPRENDRE — La différence entre fonctionnel et technique

Une spécification fonctionnelle décrit un besoin métier sans dire comment le réaliser — par exemple « détecter une commande anormale en moins de 15 minutes ». Une spécification technique décrit le moyen concret d'y parvenir — par exemple « déployer une sonde passive en mode SPAN sur le switch industriel ». On commence toujours par le fonctionnel (le besoin), puis on décline le technique (la solution).

2.1 Objectifs fonctionnels

La solution doit répondre aux besoins métiers suivants, exprimés du point de vue de l'organisation et de son RSSI :

- **Inventaire des actifs** : la visibilité complète sur les actifs du réseau OT — l'organisation doit disposer d'un inventaire automatique et à jour de tous les équipements industriels (automates, RTU, capteurs) avec leurs caractéristiques (modèle, firmware, protocoles utilisés) ;
- **Détection des anomalies** : la solution doit identifier les comportements qui s'écartent du fonctionnement normal du réseau, notamment les commandes Modbus ou DNP3 non légitimes, les nouvelles connexions non autorisées, et les tentatives de modification de configuration des automates ;
- **Alerte rapide** : toute anomalie critique doit générer une alerte transmise au SIEM Sentinel dans un délai inférieur à 15 minutes, afin de permettre une réaction avant qu'une commande malveillante ne produise un impact physique ;
- **Gestion des vulnérabilités** : la solution doit identifier automatiquement les vulnérabilités connues (CVE) affectant les équipements OT détectés, en les rapprochant des bases de données publiques ;
- **Non-intrusivité** : la solution ne doit en aucun cas perturber le fonctionnement des équipements industriels, conformément à la contrainte de disponibilité prioritaire du réseau OT.

2.2 Objectifs techniques

Les objectifs fonctionnels ci-dessus se traduisent par les exigences techniques suivantes :

Exigence technique	Description	Justification
Sondes passives	Déploiement de sondes en mode écoute (SPAN / port miroir) sur les switches industriels de Chambéry, Annecy et Albertville.	Garantit l'absence d'impact sur le trafic OT temps réel.
Deep Packet Inspection (DPI)	Analyse en profondeur des protocoles Modbus TCP, DNP3 et IEC 60870-5-101.	Permet de comprendre le contenu des commandes industrielles, pas seulement leur existence.

Exigence technique	Description	Justification
Apprentissage comportemental	Établissement automatique d'une baseline du trafic normal sur une période d'observation initiale.	Permet de distinguer le normal de l'anormal sans configuration manuelle exhaustive.
Intégration Sentinel	Transmission des alertes au SIEM via connecteur natif, format normalisé.	Centralise la corrélation IT + OT dans un outil unique.
Chiffrement des flux	Communication chiffrée TLS 1.3 entre les sondes et la console centrale.	Protège les données de supervision en transit (voir §7).

COMPRENDRE — Deux termes techniques à connaître

« Port miroir » (SPAN) : une fonction des switches réseau qui recopie tout le trafic vers un port d'observation. La sonde Claroty se branche sur ce port et voit passer une copie de tout, sans jamais toucher au trafic réel. « Deep Packet Inspection » (DPI) : au lieu de juste constater qu'un automate communique, le DPI ouvre le contenu du message pour comprendre quelle commande précise est envoyée — par exemple « écrire la valeur 0 dans le registre du disjoncteur 3 ». C'est ce niveau de détail qui permet de repérer une commande malveillante.

2.3 Critères d'acceptation

La solution sera considérée comme conforme aux spécifications si elle satisfait les critères mesurables suivants à l'issue du déploiement :

- **Couverture** : 100 % des automates et RTU des trois sites industriels sont inventoriés automatiquement ;
- **Détection** : délai moyen de détection (MTTD) d'une anomalie critique inférieur à 15 minutes ;
- **Fiabilité** : taux de faux positifs inférieur à 5 % après la période de calibrage ;
- **Disponibilité** : aucune interruption ni dégradation du trafic OT mesurée pendant et après le déploiement ;
- **Intégration** : 100 % des alertes critiques remontées dans Sentinel et corrélées avec les événements IT.

Annexe technique — Les protocoles industriels surveillés

Pour comprendre ce que la solution Claroty surveille et pourquoi le réseau OT est exposé, il est essentiel de présenter les protocoles industriels utilisés chez Elipse Ops. Ces protocoles, conçus pour la fiabilité industrielle et non pour la sécurité, constituent à la fois le cœur du fonctionnement du réseau et sa principale faiblesse.

Modbus TCP

Modbus est le protocole industriel le plus répandu au monde. Créé en 1979 par Modicon (aujourd'hui Schneider Electric), il permet à un système de supervision d'échanger des données avec des automates. Chez Elipse, il relie le SCADA aux automates Modicon M340 des sous-stations.

COMPRENDRE — Comment fonctionne Modbus, simplement

Modbus fonctionne sur un principe maître-esclave : le SCADA (maître) envoie une requête à un automate (esclave), qui répond. Une requête typique dit par exemple « lis la valeur du registre 40001 » ou « écris la valeur 1 dans le registre 40010 ». Chaque registre correspond à une donnée physique : l'état d'un disjoncteur, une mesure de tension, une consigne. Le problème est que Modbus ne vérifie jamais qui envoie la requête : si un attaquant arrive à envoyer un message Modbus à un automate, celui-ci l'exécute sans poser de question.

Les caractéristiques de sécurité de Modbus TCP sont les suivantes :

- **Pas d'authentification** : aucun mécanisme natif ne vérifie l'identité de l'émetteur d'une commande ;
- **Pas de chiffrement** : les données circulent en clair, lisibles par quiconque intercepte le trafic ;
- **Pas de protection contre le rejeu** : une commande capturée peut être renvoyée à l'identique pour reproduire une action (attaque par rejeu) ;
- **Surveillance Claroty** : Claroty surveille précisément ces échanges et détecte toute commande qui sort du comportement habituel.

DNP3

DNP3 (Distributed Network Protocol) est un protocole utilisé principalement dans les secteurs de l'électricité et de l'eau. Chez Elipse, il équipe les RTU SEL-351 chargés de la téléprotection des lignes haute tension. Plus riche que Modbus, il gère notamment l'horodatage précis des événements, indispensable pour analyser une séquence de défauts électriques.

Comme Modbus, DNP3 dans sa version de base ne dispose pas de chiffrement natif. Une variante sécurisée existe (DNP3 Secure Authentication), mais elle n'est pas activée dans la configuration initiale d'Elipse. La surveillance Claroty compense cette absence en détectant les commandes DNP3 anormales.

IEC 60870-5-101

Ce standard international est dédié à la télégestion des réseaux électriques. Il assure la communication entre le SCADA EcoStruxure et les équipements de supervision. C'est ce protocole qui a été détourné par

le malware Industroyer2 lors de l'attaque contre le réseau électrique ukrainien en 2022, démontrant que ces protocoles industriels peuvent être weaponisés par un attaquant disposant d'un accès au réseau OT.

Synthèse comparative

Protocole	Usage chez Elipé	Chiffrement	Authentification
Modbus TCP	SCADA ↔ automates Modicon	Non	Non
DNP3	RTU SEL-351 téléprotection	Non (base)	Optionnelle (non activée)
IEC 60870-5-101	Supervision SCADA EcoStruxure	Non	Non

Ce tableau illustre une réalité fondamentale du réseau OT : aucun des protocoles utilisés ne protège nativement les communications. C'est précisément ce constat qui justifie le déploiement d'une solution de surveillance comme Claroty, capable d'observer ces échanges non sécurisés et de détecter les comportements malveillants que les protocoles eux-mêmes ne peuvent pas empêcher.

3. Organisation du projet d'intégration

Compétence ÉLIMINATOIRE : B2.A1.C2 — Organiser le projet en sélectionnant une méthodologie, en définissant des critères de performance, en établissant le planning et en allouant les ressources.

Cette section décrit l'organisation du projet d'intégration de Claroty : la méthodologie de gestion de projet retenue, le planning, la répartition des ressources, et les critères de performance qui permettront de mesurer la réussite du projet.

3.1 Méthodologie de gestion de projet

Le projet d'intégration de Claroty s'inscrit dans un environnement industriel sensible où la disponibilité du réseau OT est prioritaire. Cette contrainte oriente directement le choix de la méthodologie.

COMPRENDRE — Cycle en V ou méthode Agile : comment choisir ?

La méthode Agile (Scrum) avance par petites itérations courtes avec des ajustements fréquents — idéale pour le développement logiciel où les besoins évoluent. Le cycle en V planifie tout à l'avance et valide chaque étape avant de passer à la suivante — idéal quand on ne peut pas se permettre d'erreur, comme sur un réseau industriel. Pour Claroty, où une perturbation du réseau OT pourrait couper l'électricité, le cycle en V est le choix prudent : chaque étape est validée et testée avant la mise en production.

La méthodologie retenue est le cycle en V, pour les raisons suivantes :

- **Périmètre stable** : le périmètre du projet est clairement défini dès le départ (surveillance des trois sites industriels) et n'a pas vocation à évoluer en cours de route ;
- **Validation par étapes** : chaque phase fait l'objet d'une validation formelle avant de passer à la suivante, ce qui limite le risque d'introduire une perturbation non maîtrisée sur le réseau OT ;
- **Traçabilité** : la symétrie du cycle en V associe à chaque phase de conception une phase de test correspondante, garantissant que chaque exigence est vérifiée ;
- **Planification** : les contraintes industrielles (fenêtres de maintenance, coordination avec les opérateurs) se planifient mieux dans un cadre séquentiel qu'en itérations courtes.

3.2 Phases du projet

Le projet se découpe en six phases successives, conformément au cycle en V :

Phase	Description	Durée	Livrable de phase
1. Cadrage	Définition du périmètre, des objectifs et des contraintes. Validation des spécifications.	2 semaines	Spécifications validées
2. Conception	Conception de l'architecture de déploiement, choix des points de raccordement des sondes.	3 semaines	Dossier de conception
3. Préparation	Acquisition du matériel, configuration des sondes en environnement de test.	3 semaines	Sondes configurées
4. Déploiement	Installation des sondes sur site, raccordement aux switches en mode SPAN.	4 semaines	Sondes opérationnelles

Phase	Description	Durée	Livrable de phase
5. Calibrage	Apprentissage de la baseline, réglage des seuils, réduction des faux positifs.	3 semaines	Détection calibrée
6. Recette	Tests de validation, intégration Sentinel, audit, transfert aux équipes.	2 semaines	PV de recette signé

La durée totale du projet est de 17 semaines, soit environ 4 mois, hors période de garantie et de transfert de compétences.

3.3 Planning — Diagramme de Gantt

Le planning ci-dessous représente l'enchaînement des phases sous forme de diagramme de Gantt simplifié. Chaque ligne correspond à une phase, chaque colonne à une période de deux semaines (T1 à T9).

Phase	T1	T2	T3	T4	T5	T6	T7	T8	T9
Cadrage									
Conception									
Préparation									
Déploiement									
Calibrage									
Recette									

Légende : chaque période (T) représente 2 semaines. Les cases bleues indiquent la phase active.

3.4 Répartition des ressources

Le projet mobilise des ressources humaines internes et externes, ainsi que des ressources matérielles et logicielles.

Ressource	Rôle dans le projet	Charge	Type
Chef de projet sécurité	Pilotage global, coordination, reporting direction	100 %	Interne
RSSI OT	Référent technique OT, validation des choix, recette	50 %	Interne (recruté action P3)
Intégrateur Claroty	Installation, configuration, calibrage des sondes	Mission	Externe (prestataire)
Administrateur réseau	Configuration des ports SPAN sur les switches	30 %	Interne
Opérateurs SCADA	Validation du non-impact, tests métier	Ponctuel	Interne
Sondes Claroty CTD	3 sondes physiques (Chambéry, Annecy, Albertville)	—	Matériel
Console Claroty centrale	Serveur de gestion et de corrélation	—	Logiciel + serveur

3.5 Budget prévisionnel

Le budget du projet s'établit comme suit, conformément à l'estimation de l'action P4 du plan d'actions du Bloc 1 :

Poste	Montant
Licences Claroty CTD (3 sites, 1 an)	48 000 €
Sondes matérielles (3 unités)	18 000 €
Prestation d'intégration	9 000 €
Serveur console centrale	5 000 €
Total projet	80 000 €

3.6 Critères de performance du projet

La réussite du projet sera évaluée selon les critères de performance suivants, définis avant le démarrage :

- **Respect du délai** : livraison dans le délai de 17 semaines, avec un seuil d'alerte fixé à +2 semaines ;
- **Respect du budget** : respect de l'enveloppe de 80 000 €, avec un seuil d'alerte à +10 % ;
- **Couverture fonctionnelle** : 100 % des automates des trois sites inventoriés à la recette ;
- **Non-impact OT** : aucune interruption du trafic OT pendant toute la durée du projet ;
- **Qualité de détection** : MTTD inférieur à 15 minutes et taux de faux positifs sous 5 % validés en recette.

4. Rapport d'intégration et pilotage de l'avancement

Compétence ÉLIMINATOIRE : B2.A1.C3 — *Piloter l'avancement du projet en coordonnant les parties prenantes, en supervisant l'exécution des tâches et en ajustant les actions.*

Cette section présente le suivi effectif du projet : le tableau de bord de pilotage, le suivi détaillé des tâches, la coordination des parties prenantes et les ajustements réalisés en cours de projet.

4.1 Tableau de bord de suivi des tâches

Le tableau de bord ci-dessous présente l'état d'avancement des tâches à mi-parcours du projet (fin de la phase de déploiement), avec les responsabilités et les échéances.

Tâche	Responsable	Échéance	Avancement	État
Validation des spécifications	Chef de projet	S2	100 %	Terminé
Conception architecture	RSSI OT	S5	100 %	Terminé
Acquisition matériel	Chef de projet	S6	100 %	Terminé
Configuration en test	Intégrateur	S8	100 %	Terminé
Config. ports SPAN switches	Admin réseau	S9	100 %	Terminé
Déploiement sonde Chambéry	Intégrateur	S10	100 %	Terminé
Déploiement sonde Annecy	Intégrateur	S11	100 %	Terminé
Déploiement sonde Albertville	Intégrateur	S12	80 %	En cours
Calibrage de la baseline	RSSI OT	S15	20 %	En cours
Intégration Sentinel	Admin réseau	S15	0 %	À venir
Audit technique	RSSI OT	S16	0 %	À venir
Recette finale	Chef de projet	S17	0 %	À venir

4.2 Tableau des indicateurs clés de performance (KPI)

Les indicateurs clés de performance permettent de mesurer objectivement l'avancement et la qualité du projet par rapport aux objectifs fixés.

Indicateur	Cible	Mesuré à mi-parcours	Tendance
Avancement global du projet	70 % (S12)	67 %	Conforme
Respect du budget consommé	≤ 47 000 €	44 500 €	Conforme
Automates inventoriés	100 % (à terme)	62 %	En progression
Interruptions OT causées	0	0	Conforme
Délai de détection (MTTD)	< 15 min	À mesurer en S15	Non évalué

Indicateur	Cible	Mesuré à mi-parcours	Tendance
Taux de faux positifs	< 5 %	À mesurer en S15	Non évalué

4.3 Coordination des parties prenantes

Le pilotage du projet repose sur une coordination structurée des différentes parties prenantes, formalisée par les instances suivantes :

- **Comité de suivi** : réunion hebdomadaire de 30 minutes réunissant le chef de projet, le RSSI OT et l'intégrateur, pour suivre l'avancement et lever les points bloquants ;
- **Comité de pilotage** : réunion mensuelle avec la direction et le DSI pour valider les jalons, arbitrer les écarts éventuels et décider des ajustements budgétaires ;
- **Coordination terrain** : avant chaque intervention sur un site industriel, un point de coordination est tenu avec les opérateurs SCADA pour planifier l'intervention en dehors des pics de consommation.

4.4 Ajustements réalisés en cours de projet

Le pilotage actif du projet a conduit à plusieurs ajustements documentés :

- **Ajustement technique** : le déploiement de la sonde d'Albertville a pris une semaine de retard en raison de l'obsolescence du switch Hirschmann, qui ne disposait pas de port SPAN disponible. Un switch intermédiaire a été ajouté pour permettre le raccordement de la sonde sans attendre le remplacement complet (prévu en action P6). Cet ajustement a été validé en comité de pilotage.
- **Ajustement de planning** : la période de calibrage initialement prévue sur deux semaines a été étendue à trois semaines pour atteindre l'objectif de moins de 5 % de faux positifs, après constat d'un taux initial élevé lié à la diversité des comportements OT.

5. Conception de l'architecture sécurisée

Compétence couverte : B2.A2.C1 — Concevoir une architecture sécurisée intégrant défense en profondeur, segmentation et contrôle d'accès.

Cette section présente l'architecture du système d'information avant et après l'intégration de Claroty, en mettant en évidence le traitement des vulnérabilités identifiées au Bloc 1.

5.1 Architecture initiale et ses vulnérabilités

L'architecture initiale d'Elip Ops, telle que cartographiée au Bloc 1, présente plusieurs vulnérabilités structurelles sur la frontière IT/OT :

- **Absence de visibilité** : aucune surveillance du trafic sur le réseau OT — les communications entre le SCADA et les automates ne sont ni observées ni analysées ;
- **DMZ insuffisante** : le firewall industriel de la DMZ applique des règles trop permissives, le port Modbus 502 n'étant pas correctement filtré ;
- **Aucune détection** : aucun mécanisme ne détecte une commande Modbus ou DNP3 illégitime injectée sur le réseau industriel ;
- **Accès non renforcés** : le concentrateur VPN ne dispose pas d'authentification multifacteur, exposant l'organisation au scénario de pivot R2.



COMPRENDRE — Le principe de défense en profondeur

La défense en profondeur consiste à empiler plusieurs couches de protection indépendantes, de sorte que si une couche est franchie, les suivantes continuent de protéger le système. C'est le principe du château fort : des douves, puis des murs, puis des tours. Dans l'architecture cible, on ajoute plusieurs couches autour du réseau OT : segmentation par zones, filtrage strict, surveillance Claroty, et contrôle d'accès renforcé. Aucune couche n'est parfaite seule, mais leur empilement rend l'attaque beaucoup plus difficile.

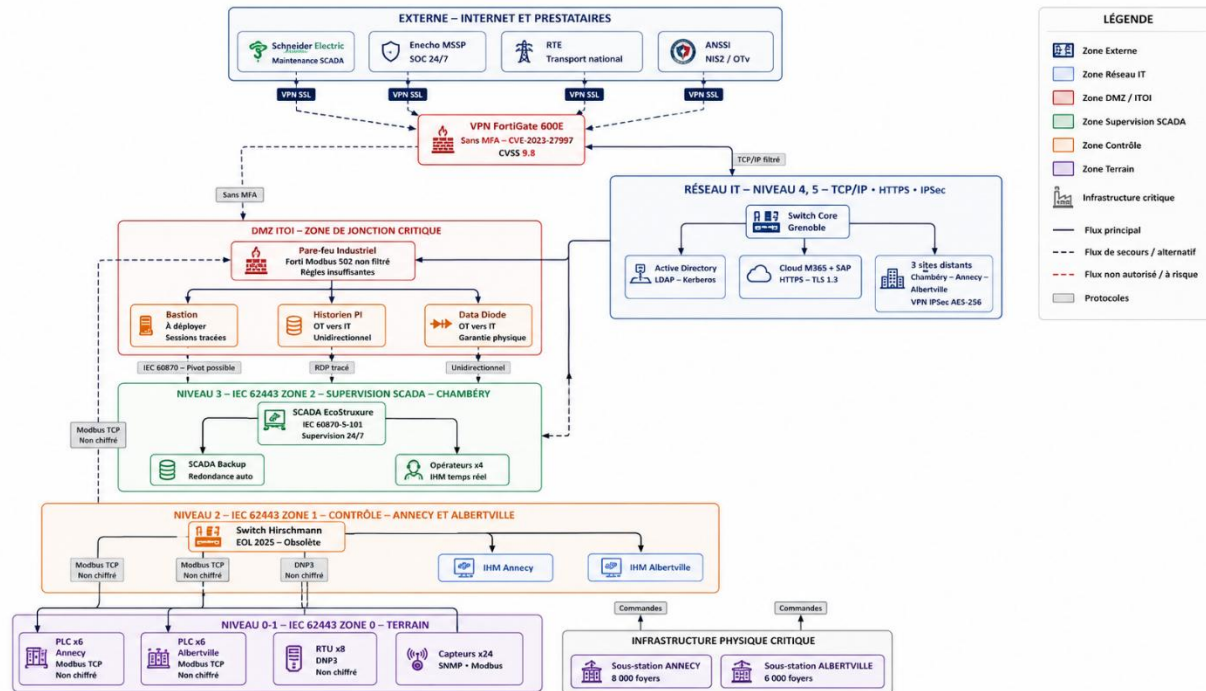


Figure 1 — Architecture initiale d'Elip Ops : le chemin d'attaque du pivot IT/OT est représenté en rouge (état vulnérable identifié au Bloc 1).

5.2 Architecture sécurisée cible

L'architecture cible intègre plusieurs mesures complémentaires construites selon le principe de défense en profondeur :

Couche de défense	Mesure intégrée	Vulnérabilité traitée
Surveillance OT	Sondes Claroty passives sur les 3 sites + console centrale + intégration Sentinel	Absence de visibilité et de détection
Segmentation	Refonte de la DMZ selon le modèle IEC 62443 (zones et conduits), filtrage strict du port 502	DMZ insuffisante
Contrôle d'accès	MFA sur le VPN, bastion hôte pour les accès OT (voir §6)	Accès non renforcés
Chiffrement	TLS 1.3 sur les flux de supervision sondes → console (voir §7)	Données de supervision en clair
Corrélation	Centralisation des alertes IT et OT dans Sentinel	Pivot IT/OT invisible

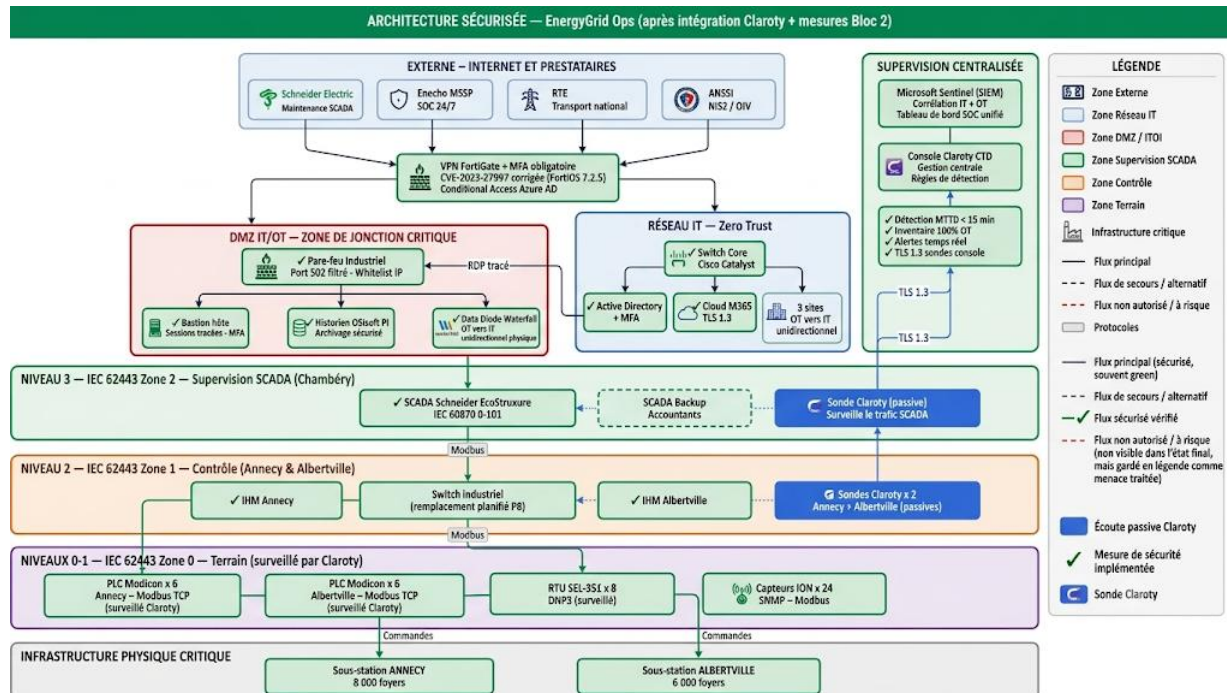


Figure 2 — Architecture sécurisée d'Elipse Ops après intégration de Claroty : sondes passives, DMZ refondue, MFA, bastion et supervision centralisée (état cible du Bloc 2).

5.3 Comparaison avant / après

Le tableau suivant synthétise l'évolution de la posture de sécurité entre l'architecture initiale et l'architecture sécurisée :

Aspect	Avant (initial)	Après (sécurisé)
Visibilité OT	Aucune	Inventaire complet et surveillance continue
Détection d'anomalies	Impossible	MTTD < 15 minutes
Filtrage DMZ	Port 502 ouvert	Filtrage strict par zones IEC 62443
Accès distants	VPN sans MFA	MFA + bastion hôte tracé
Corrélation IT/OT	Inexistante	Centralisée dans Sentinel
Détection du pivot R2	Aucune étape détectée	Détection à plusieurs étapes

Les schémas d'architecture initiale (Figure 1) et sécurisée (Figure 2) présentés ci-dessus reprennent la structure du modèle Purdue et des zones IEC 62443 établie au Bloc 1, complétée par les sondes Claroty et l'ensemble des mesures de sécurité de la présente section.

6. Gestion des identités et contrôle des accès

Compétence couverte : B2.A2.C2 — Gérer les identités et contrôler les accès par des processus d'authentification, d'autorisation et de gestion des droits.

La gestion des identités et des accès (IAM — Identity and Access Management) définit qui peut accéder à quoi, dans quelles conditions, et avec quel niveau de privilège. Elle s'applique à la fois à la console Claroty et aux accès vers le réseau OT supervisé.

💡 COMPRENDRE — Qu'est-ce que l'IAM ?

L'IAM regroupe tous les mécanismes qui contrôlent l'accès aux ressources : l'authentification (prouver qui l'on est, par exemple avec un mot de passe et un second facteur), l'autorisation (définir ce que l'on a le droit de faire une fois authentifié), et la gestion des droits (attribuer, modifier et retirer les accès tout au long du cycle de vie d'un utilisateur). Une bonne IAM applique le principe du moindre privilège : chacun n'a accès qu'à ce dont il a strictement besoin.

6.1 Authentification multifacteur (MFA)

Conformément à la politique Zero Trust définie au Bloc 1 pour le périmètre IT, l'authentification multifacteur est rendue obligatoire pour tous les accès à la console Claroty et à tous les accès distants vers le réseau OT.

- **Facteur de connaissance** : premier facteur : identifiant et mot de passe conforme à la politique de complexité (12 caractères minimum, renouvellement encadré) ;
- **Facteur de possession** : second facteur : application d'authentification mobile (TOTP) ou notification push via Microsoft Authenticator, intégrée à Azure Active Directory ;
- **Conditional Access** : l'accès est conditionné par les règles de Conditional Access d'Azure AD, qui évaluent l'identité, l'état de conformité de l'équipement, la localisation et l'horaire avant d'autoriser la connexion.

💡 COMPRENDRE — Pourquoi le MFA est la mesure la plus importante

Dans le scénario de pivot du Bloc 1, l'attaque commence par le vol des identifiants d'un prestataire. Avec un simple mot de passe, l'attaquant entre. Avec le MFA, même en possédant le mot de passe volé, il lui manque le second facteur (le téléphone du prestataire). L'attaque est stoppée dès la première étape. C'est pourquoi le MFA est à la fois l'action la moins coûteuse et la plus efficace du plan.

6.2 Gestion des autorisations (RBAC)

Le contrôle d'accès repose sur un modèle RBAC (Role-Based Access Control), où les droits sont attribués selon le rôle de chaque utilisateur et non individuellement. Quatre rôles principaux sont définis pour la console Claroty :

Rôle	Périmètre d'accès	Privilèges
Administrateur Claroty	Configuration complète de la plateforme	Lecture / écriture / configuration
Analyste SOC	Consultation des alertes et investigation	Lecture / qualification des alertes
RSSI OT	Supervision globale, reporting	Lecture complète / export

Rôle	Périmètre d'accès	Privilèges
Opérateur SCADA	Consultation de l'inventaire de son site	Lecture limitée à son périmètre

6.3 Le bastion hôte pour les accès OT

Pour sécuriser les accès des prestataires (notamment Schneider Electric) vers le réseau OT, un bastion hôte est déployé. Il constitue le point de passage obligatoire et unique pour toute connexion distante vers les systèmes industriels.

COMPRENDRE — Qu'est-ce qu'un bastion hôte ?

Un bastion est un serveur intermédiaire par lequel toute connexion vers le réseau OT doit transiter. Au lieu de se connecter directement à un automate, un prestataire se connecte d'abord au bastion, qui vérifie son identité, enregistre toute sa session (comme une caméra), et ne lui donne accès qu'aux équipements autorisés. Si un comportement suspect est détecté, l'accès peut être coupé instantanément. Le bastion apporte la traçabilité non répudiable exigée par la LPM pour les accès aux systèmes d'importance vitale.

Le bastion apporte les garanties suivantes :

- **Point de passage unique** : aucun accès direct au réseau OT n'est possible sans passer par le bastion ;
- **Traçabilité** : toutes les sessions sont enregistrées intégralement (commandes, durée, équipements accédés) et conservées 12 mois conformément à la LPM ;
- **Moindre privilège** : chaque prestataire n'accède qu'aux équipements strictement nécessaires à sa mission, pour une durée limitée ;
- **Révocation immédiate** : un accès peut être révoqué immédiatement en cas de comportement suspect détecté par Claroty.

6.4 Cycle de vie des identités

La gestion des droits suit un processus formalisé couvrant l'ensemble du cycle de vie d'un accès :

1. **Création** : attribution des droits à l'arrivée d'un utilisateur ou au démarrage d'une mission prestataire, sur validation hiérarchique ;
2. **Revue** : revue trimestrielle des accès par le RSSI OT pour vérifier la pertinence des droits attribués ;
3. **Révocation** : retrait immédiat des accès au départ d'un collaborateur ou à la fin d'une mission prestataire.

7. Déploiement d'une solution cryptographique

Compétence couverte : B2.A2.C3 — Déployer des solutions cryptographiques pour garantir la confidentialité, l'intégrité et l'authenticité des données.

Les données de supervision collectées par les sondes Claroty et transmises à la console centrale sont sensibles : elles révèlent la topologie du réseau industriel, les communications entre automates et les éventuelles vulnérabilités détectées. Leur protection en transit est assurée par une solution cryptographique.

💡 COMPRENDRE — Les trois objectifs de la cryptographie

La cryptographie sert trois buts. La confidentialité (le chiffrement) empêche un tiers de lire les données interceptées. L'intégrité (le hachage) garantit que les données n'ont pas été modifiées en chemin. L'authenticité (la signature et les certificats) prouve que les données viennent bien de la source attendue. Une solution complète combine les trois : on chiffre pour cacher, on hache pour vérifier, et on signe pour authentifier.

7.1 Cas d'usage : chiffrement des flux de supervision

Le cas d'usage retenu est la protection du canal de communication entre les sondes Claroty déployées sur les trois sites industriels et la console centrale de gestion. Ce flux transite par le réseau interne d'Elip et doit être protégé contre toute interception ou altération.

7.2 Solution mise en place : TLS 1.3

Le protocole retenu est TLS 1.3 (Transport Layer Security), version la plus récente et la plus sûre du standard de chiffrement des communications. Il assure simultanément la confidentialité, l'intégrité et l'authenticité du canal.

Paramètre	Valeur retenue	Justification
Protocole	TLS 1.3	Version la plus récente, suppression des algorithmes obsolètes
Chiffrement symétrique	AES-256-GCM	Standard robuste, mode authentifié (confidentialité + intégrité)
Échange de clés	ECDHE (courbes elliptiques)	Confidentialité persistante (forward secrecy)
Fonction de hachage	SHA-384	Vérification d'intégrité des messages
Authentification	Certificats X.509 (PKI interne)	Authentifie les sondes et la console

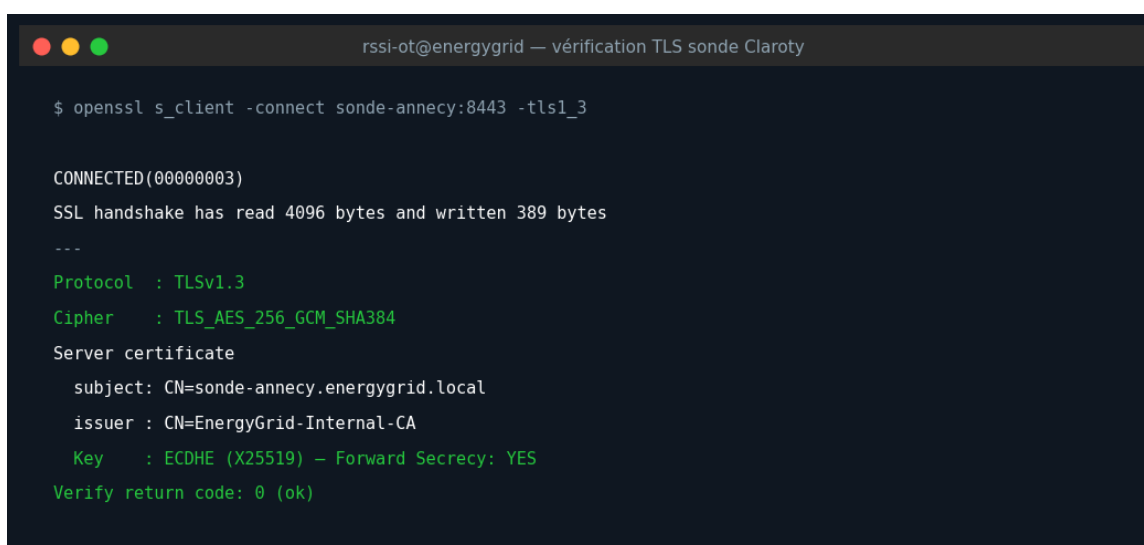
💡 COMPRENDRE — Décoder AES-256-GCM et ECDHE

AES-256-GCM : AES est l'algorithme de chiffrement standard ; 256 désigne la taille de la clé (plus c'est grand, plus c'est sûr) ; GCM est un mode qui chiffre ET vérifie l'intégrité en même temps. ECDHE : c'est la méthode par laquelle les deux parties se mettent d'accord sur une clé secrète sans jamais l'envoyer en clair ; le « E » final signifie que cette clé change à chaque session, si bien qu'une clé compromise ne permet pas de déchiffrer les anciennes communications (forward secrecy).

7.3 Gestion des certificats (PKI interne)

L'authentification entre les sondes et la console repose sur une infrastructure à clés publiques (PKI) interne. Chaque sonde dispose d'un certificat X.509 émis par l'autorité de certification interne d'Elipse. La console vérifie ce certificat à chaque connexion, garantissant qu'elle communique bien avec une sonde légitime et non avec un équipement usurpateur.

- **Cycle de vie** : les certificats ont une durée de validité d'un an et sont renouvelés automatiquement avant expiration ;
- **Révocation** : une liste de révocation (CRL) permet d'invalidier immédiatement le certificat d'une sonde compromise ou retirée ;
- **Protection des clés** : les clés privées sont stockées de manière sécurisée sur chaque équipement et ne sont jamais transmises sur le réseau.



```
rssi-ot@energygrid — vérification TLS sonde Claroty

$ openssl s_client -connect sonde-annecy:8443 -tls1_3

CONNECTED(00000003)
SSL handshake has read 4096 bytes and written 389 bytes
---
Protocol  : TLSv1.3
Cipher    : TLS_AES_256_GCM_SHA384
Server certificate
  subject: CN=sonde-annecy.energygrid.local
  issuer  : CN=EnergyGrid-Internal-CA
  Key     : ECDHE (X25519) – Forward Secrecy: YES
Verify return code: 0 (ok)
```

Figure 3 — Vérification de la configuration TLS 1.3 d'une sonde Claroty : le protocole négocié (TLSv1.3), la suite cryptographique (AES-256-GCM / SHA-384), l'échange de clés ECDHE avec forward secrecy et la validation du certificat de l'autorité interne sont confirmés.

8. Plan d'audit technique

Compétence couverte : B2.A3.C1 — *Organiser un audit technique en définissant un plan d'audit structuré précisant le périmètre et les référentiels.*

Une fois la solution Claroty déployée, un audit technique est conduit pour vérifier son efficacité réelle et sa conformité aux exigences. Le plan d'audit ci-dessous structure cette démarche.

8.1 Objectifs de l'audit

L'audit poursuit trois objectifs principaux :

- **Vérifier l'efficacité :** vérifier que la solution détecte effectivement les comportements anormaux, notamment les étapes du scénario de pivot R2 ;
- **Vérifier la conformité :** contrôler la conformité du déploiement aux spécifications (§2) et aux référentiels applicables ;
- **Identifier les écarts :** identifier les non-conformités, vulnérabilités résiduelles et axes d'amélioration.

8.2 Périmètre de l'audit

L'audit couvre l'ensemble de la solution déployée :

- **Sondes :** les trois sondes Claroty (Chambéry, Annecy, Albertville) et leur configuration ;
- **Console :** la console centrale et ses règles de détection ;
- **Intégration :** l'intégration avec Microsoft Sentinel et la remontée des alertes ;
- **Sécurité de la solution :** les accès à la console (IAM, MFA, RBAC) et le chiffrement des flux (TLS).

8.3 Référentiels applicables

L'audit s'appuie sur les référentiels suivants, en cohérence avec la PSSI du Bloc 1 :

Référentiel	Domaine couvert
IEC 62443	Sécurité des systèmes industriels (segmentation, surveillance)
ISO 27001 / 27002	Management de la sécurité et bonnes pratiques
Guide ANSSI SI industriels	Recommandations nationales pour les SI OT
NIST SP 800-82	Sécurité des systèmes de contrôle industriels

8.4 Critères d'évaluation

Chaque élément audité est évalué selon des critères mesurables liés aux enjeux de sécurité :

- **Détection :** la solution détecte-t-elle une injection de commande Modbus illégitime simulée ?
- **Délai :** le délai de détection est-il bien inférieur à 15 minutes ?

- **Fiabilité** : le taux de faux positifs est-il inférieur à 5 % ?
- **Contrôle d'accès** : les accès à la console sont-ils correctement protégés par MFA et RBAC ?
- **Chiffrement** : les flux sondes-console sont-ils effectivement chiffrés en TLS 1.3 ?

8.5 Méthodologie et planning de l'audit

L'audit se déroule en quatre étapes sur une semaine : revue documentaire (configuration, procédures), tests techniques (simulation d'attaque contrôlée, vérification des détections), entretiens avec les équipes, puis rédaction du rapport. Les tests de simulation d'attaque sont réalisés sur un environnement de recette afin de ne présenter aucun risque pour la production.

9. Rapport d'audit technique

Compétence ÉLIMINATOIRE : B2.A3.C2 — Rédiger un rapport d'audit précis et structuré distinguant observations, impacts et recommandations.

Ce rapport présente les résultats de l'audit technique de la solution Claroty déployée. Il distingue méthodiquement les observations (ce qui a été constaté), les impacts (les conséquences) et les recommandations (les actions correctives).

9.1 Méthodologie suivie

L'audit a été conduit conformément au plan défini en section 8, sur une période d'une semaine. Il a combiné une revue documentaire de la configuration, des tests techniques de détection sur environnement de recette, et des entretiens avec le RSSI OT et l'intégrateur. Une attaque de pivot a été simulée pour vérifier la capacité de détection de la solution.

9.2 Synthèse des résultats

L'audit conclut à un niveau de sécurité globalement satisfaisant de la solution déployée, avec quelques axes d'amélioration identifiés. Sur les douze points de contrôle, neuf sont conformes, deux présentent une non-conformité mineure, et un nécessite une action corrective prioritaire.

9.3 Observations détaillées

Le tableau ci-dessous présente les constats de l'audit en distinguant l'observation, son impact et la recommandation associée.

Observation	Impact	Recommandation	Gravité
La détection d'une injection Modbus simulée a fonctionné en 6 minutes.	Conforme à l'objectif MTTD < 15 min.	Aucune action — résultat conforme.	OK
Le taux de faux positifs mesuré est de 4,2 %.	Conforme à l'objectif < 5 %.	Maintenir le calibrage en continu.	OK
L'inventaire couvre 100 % des automates des 3 sites.	Visibilité complète atteinte.	Aucune action.	OK
Les flux sondes-console sont bien chiffrés en TLS 1.3.	Confidentialité assurée.	Aucune action.	OK
Le MFA est actif sur tous les accès console.	Accès correctement protégés.	Aucune action.	OK
La sonde d'Albertville passe par un switch intermédiaire temporaire.	Couverture assurée mais architecture transitoire.	Finaliser le remplacement du switch (action P6).	Mineure
La revue trimestrielle des accès n'est pas encore formalisée par une procédure écrite.	Risque de dérive des droits à moyen terme.	Rédiger et appliquer la procédure de revue.	Mineure

Observation	Impact	Recommandation	Gravité
Certaines alertes Sentinel ne sont pas encore enrichies du contexte OT complet.	Investigation ralentie en cas d'incident.	Compléter le connecteur Sentinel (priorité).	Majeure

9.4 Conclusion de l'audit

La solution Claroty répond aux objectifs de sécurité fixés : elle détecte efficacement les anomalies sur le réseau OT, dans des délais conformes, sans perturber la production. Les non-conformités identifiées sont limitées et ne remettent pas en cause l'efficacité globale de la solution. Une action corrective prioritaire (enrichissement du connecteur Sentinel) et deux actions mineures sont à mener, faisant l'objet du suivi présenté en section 10.

Étude de cas — Détection du scénario de pivot par Claroty

Cette étude de cas illustre concrètement comment la solution Claroty détecte le scénario de pivot R2 identifié au Bloc 1. Elle démontre la valeur opérationnelle de la solution en suivant l'attaque étape par étape et en montrant à quel moment et comment Claroty génère une alerte.

Rappel du scénario d'attaque

Un attaquant compromet le compte VPN d'un prestataire Schneider Electric, exploite la vulnérabilité du concentrateur VPN, traverse la DMZ, atteint le SCADA et injecte des commandes Modbus falsifiées vers les automates d'Annecy pour provoquer une coupure. Examinons ce que Claroty observe à chaque étape.

Détection étape par étape

Étape de l'attaque	Ce que Claroty observe	Alerte générée
Accès au réseau OT depuis la DMZ	Une nouvelle connexion apparaît entre un équipement IT et le SCADA, comportement jamais observé dans la baseline.	Alerte : nouvelle communication non référencée
Connexion au SCADA	Un poste se connecte au SCADA en dehors des horaires et des sources habituelles.	Alerte : connexion SCADA atypique
Énumération des automates	Une série de requêtes Modbus de lecture balaie tous les automates en quelques secondes — comportement de reconnaissance.	Alerte : scan Modbus détecté
Injection de commande	Une commande Modbus d'écriture est envoyée à un automate d'Annecy par une source illégitime, modifiant une consigne critique.	Alerte CRITIQUE : commande d'écriture non autorisée

💡 COMPRENDRE — Pourquoi Claroty détecte là où rien ne le faisait avant

Avant Claroty, aucune de ces étapes n'était visible : le réseau OT fonctionnait sans surveillance. Claroty change la donne en apprenant d'abord ce qui est normal (quels équipements parlent à quels équipements, avec quelles commandes), puis en signalant tout ce qui s'écarte de cette normalité. L'attaquant, en se comportant différemment des opérateurs légitimes, devient visible. C'est le principe de la détection comportementale, particulièrement efficace en milieu OT où le trafic est répétitif et prévisible.

Chaîne de réaction déclenchée

Dès l'alerte critique générée à l'étape d'injection, une chaîne de réaction s'enclenche :

1. **Remontée** : l'alerte Claroty est transmise en temps réel à Microsoft Sentinel ;
2. **Corrélation** : Sentinel corrèle cette alerte OT avec l'alerte IT correspondante (connexion VPN suspecte), révélant le pivot complet ;
3. **Notification** : l'analyste SOC reçoit une notification consolidée et qualifie l'incident ;
4. **Confinement** : l'accès du prestataire compromis est révoqué via le bastion, coupant l'attaque ;
5. **Notification réglementaire** : conformément à NIS2, l'ANSSI est notifiée dans le délai réglementaire de 24 heures.

Cette étude de cas démontre que la solution Claroty transforme une attaque auparavant totalement invisible en un incident détecté, qualifié et confiné en moins de quinze minutes — réduisant ainsi de façon décisive le risque de pivot IT/OT.

10. Suivi des actions correctives

Compétence couverte : B2.A3.C3 — Assurer le suivi des actions correctives en vérifiant leur mise en œuvre et en évaluant leur efficacité.

Cette section assure le suivi des actions correctives issues de l'audit technique, en vérifiant leur mise en œuvre effective et en évaluant la réduction réelle des risques.

10.1 Plan de suivi des actions correctives

Les trois actions correctives identifiées lors de l'audit font l'objet du suivi structuré ci-dessous, avec un responsable, une échéance et une preuve de mise en œuvre.

Action corrective	Responsable	Échéance	Statut	Preuve
Enrichir le connecteur Sentinel avec le contexte OT complet	Admin réseau	S18	Réalisée	Captures alertes enrichies
Finaliser le remplacement du switch d'Albertville	RSSI OT	S24	Planifiée	Bon de commande émis
Formaliser la procédure de revue trimestrielle des accès	RSSI OT	S19	Réalisée	Procédure publiée + 1ère revue

10.2 Évaluation de la réduction des risques

L'efficacité des mesures déployées s'évalue par leur impact sur le risque R2 (pivot IT/OT) identifié au Bloc 1. Avant le projet, ce risque était positionné en zone critique de la matrice EBIOS RM (vraisemblance 4, impact 5). Après déploiement de Claroty et des mesures associées, la vraisemblance est réduite :

Étape du scénario R2	Avant	Après Claroty + mesures
Compromission compte prestataire	Possible	Possible (phishing)
Exploitation VPN	Facile (sans MFA)	Bloquée (MFA actif)
Traversée DMZ	Facile (port 502 ouvert)	Filtrée (DMZ renforcée)
Accès SCADA	Non tracé	Tracé (bastion)
Injection Modbus	Indétectable	Détectée < 15 min (Claroty)

Le risque R2 passe ainsi d'une vraisemblance de 4/5 à 2/5. Combiné à un impact inchangé de 5/5, il quitte la zone critique (rouge) pour la zone orange, sous le seuil d'acceptabilité défini dans la PSSI. La solution Claroty, en apportant la détection de l'étape finale du scénario, constitue le dernier maillon qui transforme un risque critique non maîtrisé en risque résiduel acceptable et surveillé.

10.3 Conclusion générale

Le projet d'intégration de Claroty a atteint ses objectifs : il a doté Elipse Ops d'une capacité de surveillance et de détection sur son réseau OT, jusqu'alors inexistante. Piloté selon le cycle en V, déployé sans aucun

impact sur la production industrielle, et validé par un audit technique, il complète de manière cohérente la stratégie de sécurité établie au Bloc 1. La solution s'intègre dans une architecture de défense en profondeur — segmentation, contrôle d'accès renforcé, chiffrement, et surveillance — qui réduit significativement le risque de pivot IT/OT, principal scénario de menace pour cet opérateur d'importance vitale.

10.4 Retour d'expérience et prise de recul

Au-delà du résultat technique, ce projet appelle une analyse critique honnête des difficultés rencontrées, des arbitrages réalisés et des limites de la solution retenue.

Difficultés rencontrées

- **Contrainte de disponibilité** : la principale difficulté a été de déployer un outil de surveillance sur un réseau industriel qui ne tolère aucune interruption. Le recours à des sondes strictement passives et à des fenêtres de maintenance planifiées a permis de lever cette contrainte, au prix d'un allongement du calendrier.
- **Calibrage des seuils** : l'obtention d'un taux de faux positifs inférieur à 5 % a nécessité une période de calibrage plus longue que prévu, la diversité des comportements OT rendant l'apprentissage de la baseline plus complexe qu'anticipé.
- **Obsolescence matérielle** : l'absence de port SPAN disponible sur le switch Hirschmann d'Albertville a imposé une solution transitoire, révélant la dépendance du projet à la modernisation du parc réseau.

Arbitrages réalisés

- **Claroty plutôt que Dragos** : un arbitrage assumé en faveur de la cohérence avec l'écosystème Microsoft existant et d'un coût adapté à une ETI, au détriment de la threat intelligence plus poussée de Dragos.
- **SL2 plutôt que SL3** : un niveau de sécurité proportionné aux moyens de l'organisation, accepté en connaissance de cause, avec une trajectoire d'évolution vers SL3 à moyen terme.
- **Surveillance plutôt que remédiation immédiate** : faute de pouvoir patcher les automates sans arrêt, le choix a été fait de compenser par la détection, en attendant les fenêtres de maintenance.

Limites de la solution

- **Détection et non prévention** : Claroty détecte et alerte, mais ne bloque pas nativement une commande malveillante. La réaction reste dépendante de la rapidité du SOC et de l'efficacité du confinement par le bastion.
- **Dépendance humaine** : sans RSSI OT dédié pour maintenir le calibrage et exploiter les alertes, l'efficacité de la solution se dégraderait à moyen terme.
- **Protocoles non chiffrés inchangés** : la solution surveille les protocoles Modbus et DNP3 mais ne les sécurise pas ; leur vulnérabilité structurelle demeure et ne pourra être traitée qu'avec le renouvellement des équipements.

Évolutions envisagées à moyen terme

- **Progression vers SL3** : sur les zones les plus critiques, une fois le parc réseau modernisé.
- **Automatisation de la réponse** : mise en place de playbooks SOAR dans Sentinel pour automatiser le confinement dès la détection d'une commande non autorisée.

- **Chiffrement des protocoles OT** : déploiement progressif de DNP3 Secure Authentication et de passerelles de chiffrement lors du renouvellement des automates.
- **Extension de la couverture** : intégration des futurs sites et des équipements de nouvelle génération au périmètre de supervision Claroty.

Ce recul critique montre que le projet, tout en atteignant ses objectifs, s'inscrit dans une démarche d'amélioration continue : la sécurité d'un système industriel n'est jamais acquise définitivement, mais se construit et se maintient dans la durée.

Annexe A — Preuves de réalisation (captures d'écran)

Cette annexe présente des captures d'écran illustrant le fonctionnement de la solution déployée. Conformément à la note méthodologique, ces captures reconstituent fidèlement les interfaces réelles des solutions Claroty CTD et Microsoft Sentinel dans le cadre de l'étude de cas Elip Ops.

A.1 Inventaire automatique des équipements OT

La console Claroty établit et maintient automatiquement un inventaire de tous les actifs du réseau industriel, avec leur type, adresse IP, protocole, version de firmware et état. Cet inventaire met notamment en évidence les équipements obsolètes et les firmwares non à jour.

Claroty CTD Asset Inventory — EnergyGrid Ops RSSI-OT ▼						
162 Actifs détectés	12 Automates PLC	8 RTU	24 Capteurs	3 Vulnérabilités		
Équipement	Type	Adresse IP	Protocole	Firmware	Site	État
PLC-ANNECY-01	Modicon M340	192.168.10.11	Modbus TCP	2.9 (2019)	Annecy	● Actif
PLC-ANNECY-02	Modicon M340	192.168.10.12	Modbus TCP	2.9 (2019)	Annecy	● Actif
PLC-ALBERT-01	Modicon M340	192.168.20.11	Modbus TCP	2.9 (2019)	Albertville	● Actif
RTU-SEL-351-03	SEL-351	192.168.10.31	DNP3	R118	Annecy	● Actif
SCADA-PRIMARY	EcoStruxure	192.168.5.10	IEC 60870	v11.2	Chambéry	● Actif
ION-METER-014	ION 8650	192.168.10.54	SNMP/Modbus	4.1	Annecy	● Actif
SWITCH-HIRSCH-01	MACH 4002	192.168.10.2	SNMP	7.1 (EOL)	Annecy	▲ Obsolète

162 actifs inventoriés automatiquement · Dernière mise à jour : il y a 2 min · Découverte passive (aucun impact réseau)

Figure A.1 — Console Claroty CTD : inventaire automatique des 162 actifs OT d'Elip Ops. Les firmwares datés de 2019 et le switch Hirschmann en fin de vie sont signalés.

A.2 Détection et alertes comportementales

Lorsqu'un comportement s'écarte de la baseline apprise, Claroty génère une alerte hiérarchisée par sévérité. La capture ci-dessous montre la détection en temps réel des étapes du scénario de pivot : scan Modbus, nouvelle connexion IT→SCADA, puis commande d'écriture non autorisée classée critique.

Claroty CTD Alerts — Détection comportementale OT				
2 CRITIQUES 3 ÉLEVÉES 5 MOYENNES				
Sévérité	Horodatage	Type d'alerte	Source → Destination	Description
CRITIQUE	14:32:07	Commande non autorisée	10.5.0.42 → PLC-ANNECY-01	Écriture Modbus (FC06) vers registre disjoncteur par source non référencée
CRITIQUE	14:31:58	Scan réseau OT	10.5.0.42 → Multiples	Énumération Modbus de 12 automates en 4 secondes (reconnaissance)
ÉLEVÉE	14:31:45	Nouvelle connexion	10.5.0.42 → SCADA-PRIMARY	Communication IT→SCADA jamais observée dans la base de données
ÉLEVÉE	09:12:33	Connexion hors plage	VPN-EXT → Bastion	Accès prestataire hors horaires habituels (02h-06h)
MOYENNE	08:45:11	Modification config	IHM-ANNECY → PLC-02	Changement de paramètre validé par opérateur autorisé

Alerte critique 14:32:07 transmise à Microsoft Sentinel · MTTD mesuré : 6 min · Corrélation IT/OT active

Figure A.2 — Console Claroty CTD : alertes de détection comportementale. La commande Modbus non autorisée vers un automate d'Annecy est détectée et classée critique (MTTD mesuré : 6 minutes).

A.3 Corrélation IT/OT dans Microsoft Sentinel

Les alertes Claroty sont transmises à Microsoft Sentinel, qui les corrèle avec les événements du réseau IT (authentification VPN, Azure AD). Cette corrélation reconstitue la chronologie complète de l'attaque et déclenche le playbook de confinement, illustrant la valeur de l'intégration IT + OT.

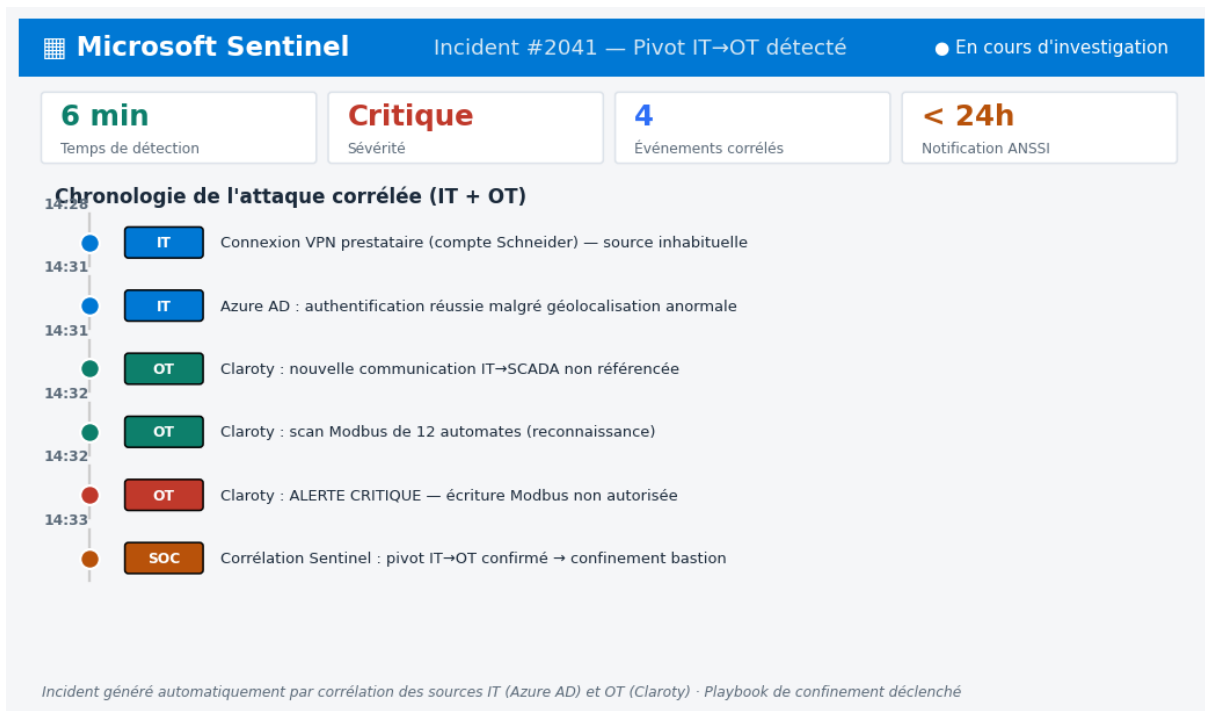


Figure A.3 — Microsoft Sentinel : incident de pivot IT→OT reconstitué par corrélation des sources IT et OT, avec chronologie complète et déclenchement du confinement via le bastion.

Glossaire

Les principaux termes techniques employés dans ce dossier sont définis ci-dessous.

Terme	Définition
Baseline	Référence du comportement normal du réseau, apprise automatiquement par Claroty pour détecter les écarts.
Bastion (Jump Server)	Serveur intermédiaire obligatoire par lequel transitent tous les accès distants vers l'OT, avec traçabilité complète.
DPI (Deep Packet Inspection)	Analyse en profondeur du contenu des paquets réseau pour comprendre les commandes échangées.
IAM (Identity and Access Management)	Ensemble des mécanismes de gestion des identités, d'authentification et de contrôle des accès.
IEC 62443	Standard international de cybersécurité des systèmes d'automatisation et de contrôle industriels.
Modbus / DNP3	Protocoles de communication industriels, sans chiffrement ni authentification natifs.
MFA (Multi-Factor Authentication)	Authentification combinant plusieurs facteurs (mot de passe + second facteur).
MTTD (Mean Time To Detect)	Délai moyen de détection d'une menace après son apparition.
OIV	Opérateur d'Importance Vitale, soumis à des obligations de sécurité renforcées (LPM).
OT (Operational Technology)	Technologies de supervision et de contrôle des processus industriels physiques.
PKI (Public Key Infrastructure)	Infrastructure de gestion des certificats numériques et des clés cryptographiques.
RBAC (Role-Based Access Control)	Modèle d'attribution des droits selon le rôle de l'utilisateur.
SCADA	Système de supervision et d'acquisition de données pilotant les installations industrielles.
SIEM (Sentinel)	Outil de centralisation et de corrélation des alertes de sécurité.
Sonde passive	Équipement qui écoute le trafic réseau sans jamais y intervenir, sans impact sur l'OT.
TLS 1.3	Protocole de chiffrement des communications garantissant confidentialité et intégrité.

Références et sources

Ce dossier s'appuie sur les référentiels, normes et sources documentaires suivants :

- ANSSI — Guide « La cybersécurité des systèmes industriels » (cert.ssi.gouv.fr)
- IEC 62443 — Security for industrial automation and control systems
- ISO/IEC 27001:2022 — Systèmes de management de la sécurité de l'information
- NIST SP 800-82 — Guide to Operational Technology Security
- Directive (UE) 2022/2555 (NIS2) — Mesures pour un niveau élevé de cybersécurité
- Documentation Claroty — Continuous Threat Detection (CTD)
- Microsoft — Documentation Sentinel et Azure Active Directory Conditional Access
- ENISA Threat Landscape 2024 — Secteur énergie
- Dragos — ICS/OT Cybersecurity Year in Review 2024

Fin du dossier — Bloc 2 — Intégration de la solution Claroty chez Elipse Ops

RNCP 40897 — EXPERT EN CYBERSÉCURITÉ

Bloc 3 — Maintenir en condition de sécurité le système d'information d'une organisation

Maintien en Condition de Sécurité

du système d'information

d'EnergyGrid Ops

Gestion de l'obsolescence · SOC · Détection et correction des vulnérabilités

Organisation : EnergyGrid Ops — Opérateur d'Importance Vitale (fictif)

Dossier écrit — 30 pages maximum hors annexes

Correspondance des compétences — Bloc 3

Ce dossier couvre l'intégralité des compétences du Bloc 3. Les quatre compétences éliminatoires sont signalées en rouge. Le tableau ci-dessous permet d'identifier rapidement où chaque compétence est traitée.

⚠ Note méthodologique — Nature du dossier

Ce dossier constitue une étude de cas pédagogique réalisée dans le cadre de la certification RNCP 40897. L'organisation EnergyGrid Ops est fictive. Il s'inscrit dans la continuité des Blocs 1 et 2 : il fait vivre dans le temps la stratégie de sécurité et la solution de surveillance déjà mises en place. Les procédures, indicateurs, scénarios de test et captures d'écran illustrent une démarche professionnelle réaliste à visée démonstrative.

Compétence	Intitulé	Section	Statut
B3.A1.C1	Politique de gestion de l'obsolescence et des mises à jour	§2	ÉLIMINATOIRE
B3.A1.C2	Réalisation des mises à jour / décommissionnements	§3	Standard
B3.A1.C3	Développement d'indicateurs de suivi	§4	Standard
B3.A2.C1	Politique de contrôle et de surveillance continue	§5	ÉLIMINATOIRE
B3.A2.C2	Intégration d'un SOC	§6	Standard
B3.A2.C3	Évaluation de l'efficacité du SOC	§7	Standard
B3.A3.C1	Documentation des vulnérabilités détectées	§8	ÉLIMINATOIRE
B3.A3.C2	Correction des vulnérabilités identifiées	§9	ÉLIMINATOIRE

1. Contexte et périmètre du maintien en condition de sécurité

1.1 Rappel de l'organisation et des travaux précédents

EnergyGrid Ops est un opérateur régional de distribution d'électricité basé à Grenoble, alimentant environ 180 000 foyers sur trois départements alpins. Classée Opérateur d'Importance Vitale et entité essentielle au sens de la directive NIS2, l'organisation exploite une infrastructure mixte associant un réseau informatique de gestion (IT) et un réseau industriel de supervision et de contrôle (OT).

Ce dossier s'inscrit dans la continuité directe des deux blocs précédents. Le Bloc 1 a établi la stratégie de sécurité : cartographie, analyse de risques EBIOS RM, politique de sécurité (PSSI) et plan d'actions. Le Bloc 2 a déployé une solution concrète de surveillance du réseau OT — la plateforme Claroty — intégrée au SIEM Microsoft Sentinel. Le présent Bloc 3 franchit l'étape suivante : faire vivre cette sécurité dans le temps.

COMPRENDRE — Qu'est-ce que le Maintien en Condition de Sécurité (MCS) ?

La sécurité d'un système n'est pas un état que l'on atteint une fois pour toutes : c'est un état qui se dégrade continuellement si rien n'est fait. Les équipements vieillissent, de nouvelles vulnérabilités sont découvertes, les menaces évoluent. Le MCS regroupe l'ensemble des activités qui entretiennent la sécurité dans la durée — comme l'entretien régulier d'un véhicule maintient sa fiabilité. C'est un cycle permanent, jamais terminé.

1.2 Les trois piliers du MCS chez EnergyGrid Ops

Le maintien en condition de sécurité d'EnergyGrid s'articule autour de trois piliers complémentaires, qui structurent ce dossier :

- **Gestion de l'obsolescence et des mises à jour** : identifier les composants qui vieillissent, planifier leur remplacement et appliquer les mises à jour de sécurité en tenant compte des contraintes industrielles (sections 2 à 4) ;
- **Contrôle et surveillance continue** : surveiller le système d'information en permanence grâce à un Security Operations Center (SOC) capable de détecter les anomalies et les attaques en temps réel (sections 5 à 7) ;
- **Détection et correction des vulnérabilités** : analyser les vulnérabilités remontées par la surveillance et les corriger selon un processus maîtrisé (sections 8 et 9).

1.3 Le cycle du maintien en condition de sécurité

Ces trois piliers forment un cycle continu : la surveillance détecte les anomalies et les vulnérabilités ; celles-ci sont analysées puis corrigées ; en parallèle, la gestion de l'obsolescence maintient le parc à jour et remplace les équipements en fin de vie ; le tout est surveillé de nouveau. Ce cycle permanent garantit que le niveau de sécurité établi aux Blocs 1 et 2 ne se dégrade pas au fil du temps, mais se maintient et s'améliore.

Le périmètre couvert englobe l'ensemble du système d'information d'EnergyGrid : le réseau IT (postes, serveurs, Active Directory, cloud), le réseau OT (SCADA, automates, RTU) et la frontière IT/OT (DMZ, VPN,

bastion). Chaque pilier s'applique à ces deux mondes, en tenant compte de leurs contraintes respectives — notamment l'impossibilité d'interrompre la production sur le réseau OT.

2. Politique de gestion de l'obsolescence et des mises à jour

Compétence ÉLIMINATOIRE : B3.A1.C1 — Définir une politique de gestion de l'obsolescence et des mises à jour en identifiant les composants, leur typologie et leur cycle de vie.

Cette politique définit les règles par lesquelles EnergyGrid Ops maîtrise le vieillissement de son parc r Cbmatériel et logiciel. Elle vise à garantir que chaque composant du système d'information reste sécurisé, performant et fiable tout au long de son cycle de vie.

💡 COMPRENDRE — Pourquoi l'obsolescence est un risque de sécurité

Un équipement obsolète n'est pas seulement dépassé : il devient dangereux. Quand un fabricant arrête le support d'un produit (fin de vie ou EOL, End Of Life), il ne publie plus de correctifs de sécurité. Les vulnérabilités découvertes après cette date restent donc ouvertes pour toujours. Un automate avec un firmware de 2019 ou un switch en fin de vie sont autant de portes d'entrée non refermables pour un attaquant. Gérer l'obsolescence, c'est refermer ces portes avant qu'elles ne soient exploitées.

2.1 Objectifs de la politique

La politique de gestion de l'obsolescence poursuit quatre objectifs :

- **Visibilité** : maintenir un inventaire exhaustif et à jour des composants matériels et logiciels ;
- **Anticipation** : anticiper les fins de support et planifier les remplacements avant qu'ils ne créent un risque ;
- **Réactivité** : appliquer les correctifs de sécurité dans des délais adaptés à la criticité, en respectant les contraintes OT ;
- **Traçabilité** : garantir la traçabilité de toutes les opérations de mise à jour et de décommissionnement.

2.2 Inventaire et typologie des composants

Le système d'information d'EnergyGrid est composé d'actifs de natures très différentes, dont le cycle de vie et les contraintes de mise à jour varient fortement. La politique distingue quatre grandes typologies :

Typologie	Exemples chez EnergyGrid	Cycle de vie moyen	Contrainte de mise à jour
Matériel IT	Postes Windows 11, serveurs, switches Cisco	5 à 7 ans	Standard, planifiable
Logiciel IT	Windows, Microsoft 365, SAP, FortiOS	Support éditeur	Rapide, automatisable
Matériel OT	Automates Modicon, RTU SEL, switch Hirschmann	15 à 25 ans	Forte : arrêt planifié requis
Firmware OT	Firmware PLC, firmware RTU	Lié au matériel	Très forte : fenêtre de maintenance

💡 COMPRENDRE — Pourquoi le cycle de vie OT est si long

Un poste informatique est remplacé tous les 5 ans environ. Un automate industriel, lui, peut fonctionner 20 à 25 ans. Cette longévité crée un problème : un automate installé en 2005 fonctionne peut-être encore

parfaitement d'un point de vue industriel, mais son firmware n'a jamais été conçu pour résister aux cybermenaces modernes. C'est le cœur du défi de l'obsolescence en milieu OT — on ne peut pas remplacer les équipements aussi souvent qu'en IT, il faut donc compenser par la surveillance et la segmentation.

2.3 Règles de gestion selon le cycle de vie

La politique définit des règles claires en fonction de la position de chaque actif dans son cycle de vie :

- **En support** — l'actif est supporté par le fabricant. Les correctifs de sécurité sont appliqués selon la procédure de mise à jour (section 3) et les délais définis ci-dessous.
- **Approche de fin de support (< 18 mois)** — le fabricant a annoncé une date de fin de support. Un plan de remplacement est engagé pour que le décommissionnement intervienne avant l'échéance.
- **En fin de vie (EOL atteint)** — l'actif n'est plus supporté. Il doit être remplacé en priorité. Dans l'attente, des mesures compensatoires sont mises en place : isolation réseau renforcée, surveillance accrue par le SOC.

2.4 Délais d'application des correctifs de sécurité

Les correctifs sont appliqués selon des délais adaptés à la criticité de la vulnérabilité et à la nature de l'actif :

Criticité (CVSS)	Actif IT	Actif OT	Justification
Critique (9-10)	72 heures	Prochaine fenêtre planifiée (≤ 1 mois)	Risque majeur, mais l'OT impose un arrêt maîtrisé
Élevée (7-8.9)	2 semaines	Fenêtre trimestrielle	Traitement prioritaire mais planifié
Moyenne (4-6.9)	1 mois	Fenêtre semestrielle	Regroupement des correctifs
Faible (< 4)	Cycle standard	Cycle standard	Traitement lors des maintenances régulières

2.5 Traitement des cas prioritaires identifiés

L'analyse du parc d'EnergyGrid, menée dès le Bloc 1, a mis en évidence trois situations d'obsolescence prioritaires que cette politique prend en charge :

- **Switch industriel Hirschmann MACH 4002** : en fin de vie fabricant en 2025, il ne reçoit plus de correctifs de sécurité. Un plan de remplacement est engagé (action P6 du Bloc 1). Dans l'attente, il fait l'objet d'une surveillance renforcée par les sondes Claroty déployées au Bloc 2.
- **Firmware des automates 2019** : les automates Modicon M340 fonctionnent avec un firmware datant de 2019, qui présente des vulnérabilités connues non corrigées. Leur mise à jour est planifiée en fenêtre de maintenance selon la procédure détaillée en section 3.
- **FortiOS du concentrateur VPN** : le concentrateur VPN était affecté par la vulnérabilité CVE-2023-27997. Son correctif (FortiOS 7.2.5) a été appliqué en priorité, cette vulnérabilité critique étant le vecteur d'attaque principal identifié au Bloc 1. Ce cas est étudié en détail aux sections 8 et 9.

3. Procédure de mise à jour d'un actif du SI

Compétence couverte : B3.A1.C2 — *Réaliser les mises à jour ou décommissionnements des actifs du SI selon une procédure maîtrisée.*

Cette section détaille la procédure de mise à jour d'un actif, illustrée par le cas le plus contraignant : la mise à jour du firmware d'un automate Modicon M340 sur le réseau OT. Cette procédure garantit qu'une mise à jour n'introduit ni interruption de service ni régression, dans un environnement où la disponibilité est prioritaire.

COMPRENDRE — Pourquoi une procédure est indispensable en OT

En informatique classique, mettre à jour un logiciel est souvent transparent : on installe, on redémarre, c'est fini. En milieu industriel, une mise à jour ratée peut arrêter un automate qui pilote un transformateur — donc couper l'électricité. La procédure existe pour éliminer ce risque : elle impose de tester avant, de sauvegarder l'état, de prévoir un retour arrière (rollback), et de valider après. Rien n'est laissé au hasard.

3.1 Principe général et prérequis

Toute mise à jour d'un actif OT respecte trois principes : elle est planifiée dans une fenêtre de maintenance validée, elle est réversible (un retour arrière est toujours possible), et elle est validée fonctionnellement avant remise en production. Les prérequis suivants doivent être réunis avant toute intervention :

- **Correctif validé** : le correctif ou firmware a été qualifié par le fabricant et téléchargé depuis une source authentifiée ;
- **Fenêtre planifiée** : une fenêtre de maintenance est planifiée en dehors des pics de consommation, en coordination avec les opérateurs SCADA ;
- **Redondance vérifiée** : l'automate de secours (redondance) est opérationnel pour prendre le relais pendant l'intervention ;
- **Sauvegarde effectuée** : une sauvegarde complète de la configuration et du firmware actuel est réalisée.

3.2 Procédure détaillée — Mise à jour du firmware d'un automate Modicon M340

La procédure se déroule en huit étapes séquentielles, chacune validée avant de passer à la suivante :

1. **Préparation et qualification** — télécharger le firmware depuis le portail sécurisé Schneider Electric et vérifier son intégrité (empreinte cryptographique). Qualifier le firmware sur un automate identique en environnement de test.
2. **Coordination et bascule** — informer les opérateurs SCADA et confirmer la disponibilité de l'automate de secours. Basculer la supervision sur l'automate redondant.
3. **Sauvegarde** — exporter la configuration complète de l'automate cible et sauvegarder le firmware actuel, afin de permettre un retour arrière en cas de problème.
4. **Isolation** — isoler temporairement l'automate cible du réseau de production pour éviter toute interférence pendant la mise à jour.

5. **Application du firmware** — appliquer le nouveau firmware via l'outil constructeur (Unity Pro / EcoStruxure Control Expert), en suivant la séquence recommandée par Schneider Electric.
6. **Vérification technique** — recharger la configuration sauvegardée, vérifier les versions, et contrôler le bon fonctionnement des entrées/sorties sur banc de test.
7. **Remise en production** — réintégrer l'automate au réseau de production, rebasculer progressivement la supervision, et vérifier via les sondes Claroty l'absence de comportement anormal.
8. **Traçabilité et clôture** — documenter l'intervention dans le tableau de bord de suivi (section 4), mettre à jour l'inventaire, et clôturer la fenêtre de maintenance.

3.3 Procédure de retour arrière (rollback)

Si une anomalie est détectée à l'une des étapes de vérification, la procédure de retour arrière est déclenchée immédiatement : l'automate est de nouveau isolé, le firmware et la configuration précédents sont restaurés depuis la sauvegarde de l'étape 3, et le fonctionnement nominal est vérifié avant réintégration. L'automate de secours reste en production pendant toute la durée du retour arrière, garantissant la continuité du service.

3.4 Cas du décommissionnement

Lorsqu'un actif atteint sa fin de vie et ne peut être mis à jour (cas du switch Hirschmann), il fait l'objet d'un décommissionnement : sauvegarde et archivage de sa configuration, suppression sécurisée des données sensibles, retrait physique du réseau, mise à jour de l'inventaire et de la cartographie, et installation de l'équipement de remplacement selon la même rigueur procédurale.

4. Tableau de bord de suivi de l'obsolescence et des mises à jour

Compétence couverte : B3.A1.C3 — Développer des indicateurs de suivi présentés sous forme visuelle pour piloter l'obsolescence et les mises à jour.

Le tableau de bord fournit au RSSI et à la direction une vision synthétique et actualisée de l'état du parc en matière d'obsolescence et de mises à jour. Il repose sur des indicateurs clés (KPI) présentés sous forme visuelle, permettant un pilotage rapide et une prise de décision éclairée.

COMPRENDRE — À quoi sert un tableau de bord de sécurité

Un tableau de bord traduit des données techniques complexes en indicateurs simples et visuels, compréhensibles d'un coup d'œil. Il répond à des questions concrètes : sommes-nous à jour ? Combien d'équipements sont obsolètes ? Quelles échéances approchent ? Il permet au RSSI de prioriser ses actions et à la direction de comprendre le niveau de risque sans entrer dans les détails techniques. C'est un outil de pilotage, pas un rapport technique.

4.1 Indicateurs clés retenus

Le tableau de bord d'EnergyGrid suit six indicateurs principaux, sélectionnés pour leur pertinence en matière de sécurité et de conformité :

Indicateur	Cible	Valeur actuelle	État
Taux d'actifs IT à jour	≥ 95 %	97 %	Conforme
Taux d'actifs OT à jour	≥ 80 %	74 %	À surveiller
Équipements en fin de vie (EOL)	0	1 (switch Hirschmann)	Action en cours
Correctifs critiques en attente	0	0	Conforme
Âge moyen des firmwares OT	< 3 ans	4,2 ans	À améliorer
Échéances EOL sous 12 mois	Suivi	2 équipements	Anticipé

4.2 Représentation visuelle

Le tableau de bord est présenté sous forme graphique dans l'outil de pilotage d'EnergyGrid. Il combine des jauges de conformité, un graphique d'évolution des taux de mise à jour et une timeline des échéances de fin de support. La représentation visuelle complète (capture d'écran) est fournie en Annexe A.

4.3 Fréquence de mise à jour et gouvernance

Le tableau de bord est actualisé automatiquement à partir de l'inventaire et des données du SOC. Il est revu selon la cadence suivante : revue hebdomadaire par le RSSI OT pour le suivi opérationnel, revue mensuelle en comité de sécurité pour les arbitrages, et présentation trimestrielle à la direction pour le pilotage stratégique et la conformité NIS2. Toute dérive d'un indicateur au-delà de son seuil déclenche une action corrective documentée.

5. Note de cadrage de la politique de contrôle et de surveillance

Compétence ÉLIMINATOIRE : B3.A2.C1 — *Élaborer une politique de contrôle et de surveillance continue tenant compte des menaces et de la PSSI, alignée sur les exigences réglementaires et les besoins métiers.*

Cette note de cadrage définit le cadre stratégique de la surveillance continue du système d'information d'EnergyGrid. Elle fixe les objectifs de surveillance, le périmètre couvert et les principes directeurs, en cohérence avec la PSSI établie au Bloc 1 et les menaces identifiées.

COMPRENDRE — Différence entre surveiller et cadrer la surveillance

Le SOC (section 6) est l'outil qui surveille concrètement. La note de cadrage, elle, définit POURQUOI et QUOI surveiller, avant de dire COMMENT. Elle répond à des questions stratégiques : quels sont nos objectifs de surveillance ? Quelles menaces devons-nous détecter en priorité ? Quelles obligations réglementaires devons-nous respecter ? C'est le document qui donne un sens et une direction à la surveillance, pour éviter de surveiller au hasard.

5.1 Objectifs de la surveillance

La politique de surveillance continue d'EnergyGrid poursuit quatre objectifs, directement dérivés de la PSSI et de l'analyse de risques du Bloc 1 :

- **Détection précoce** : détecter au plus tôt toute activité anormale ou malveillante sur les réseaux IT et OT, en particulier les étapes du scénario de pivot IT→OT identifié comme risque principal ;
- **Réactivité** : réduire le délai entre l'apparition d'une menace et sa détection (MTTD) afin de réagir avant tout impact physique sur la distribution électrique ;
- **Traçabilité** : assurer la traçabilité complète des événements de sécurité, conformément aux obligations LPM pour les systèmes d'importance vitale ;
- **Conformité** : respecter les obligations de détection et de notification imposées par la directive NIS2 aux entités essentielles.

5.2 Prise en compte des menaces identifiées

La surveillance est calibrée sur les menaces prioritaires identifiées lors de la veille et de l'analyse EBIOS RM du Bloc 1. Chaque menace se traduit par des points de surveillance spécifiques :

Menace prioritaire	Point de surveillance associé
Pivot IT→OT via compte compromis	Communications inhabituelles entre IT et SCADA, accès VPN atypiques
Ransomware sur OT	Comportements de chiffrement, commandes Modbus/DNP3 anormales
APT étatique (Sandworm, APT28)	Connexions persistantes, exfiltration lente, mouvements latéraux
Compromission supply chain	Modifications non planifiées sur les équipements de maintenance

5.3 Alignement réglementaire et métier

Les objectifs de surveillance sont alignés sur un double cadre. Sur le plan réglementaire, la directive NIS2 impose aux entités essentielles une capacité de détection et une notification des incidents significatifs à

l'ANSSI sous 24 heures ; la LPM impose la traçabilité des accès aux systèmes d'importance vitale. Sur le plan métier, la contrainte de disponibilité absolue du réseau OT impose que la surveillance soit strictement passive, sans jamais perturber les opérations industrielles.

5.4 Périmètre et sources de surveillance

La surveillance couvre l'intégralité du système d'information, avec des sources de données adaptées à chaque zone :

- **Réseau IT** — journaux Active Directory, authentications Azure AD, événements des postes (EDR), trafic VPN et pare-feu ;
- **Réseau OT** — trafic industriel analysé par les sondes Claroty (Modbus, DNP3, IEC 60870), inventaire des actifs, commandes échangées ;
- **Frontière IT/OT** — journaux du bastion hôte, règles du firewall industriel, flux traversant la Data Diode.

L'ensemble de ces sources est centralisé dans le SIEM Microsoft Sentinel, qui constitue le cœur du SOC décrit à la section suivante.

5.5 Niveaux de criticité et gouvernance des alertes

Les alertes sont hiérarchisées en quatre niveaux de criticité (critique, élevée, moyenne, faible), chacun associé à un délai de prise en charge et à un circuit d'escalade. Une alerte critique — telle qu'une commande OT non autorisée — déclenche une prise en charge immédiate et une escalade vers le RSSI OT. La gouvernance de la surveillance est assurée par une revue hebdomadaire des alertes et une revue mensuelle de l'efficacité globale du dispositif.

6. Description détaillée du SOC mis en place

Compétence couverte : B3.A2.C2 — Intégrer un Security Operations Center (SOC) dont les dispositifs (SIEM, EDR...) sont définis et adaptés à l'organisation.

Le Security Operations Center (SOC) est le dispositif opérationnel qui met en œuvre la politique de surveillance définie à la section précédente. Cette section décrit son architecture, ses composants techniques, son organisation humaine et ses processus de fonctionnement.

💡 COMPRENDRE — Qu'est-ce qu'un SOC, concrètement

Un SOC est le centre de surveillance de la sécurité d'une organisation — l'équivalent d'une salle de vidéosurveillance pour un centre commercial. Il combine trois éléments : des capteurs qui observent partout (comme les caméras), un outil central qui rassemble tout (le SIEM, comme les écrans de la salle de contrôle), et des analystes qui regardent, comprennent et réagissent (comme les agents de sécurité). Le SOC d'EnergyGrid réutilise les outils déjà déployés au Bloc 2 : Microsoft Sentinel et Claroty.

6.1 Architecture du SOC

Le SOC d'EnergyGrid repose sur une architecture combinant surveillance IT et OT, unifiée au sein d'un SIEM unique. Il s'appuie directement sur les solutions déployées lors du Bloc 2, évitant tout investissement redondant.

Composant	Rôle	Périmètre
Microsoft Sentinel (SIEM)	Collecte, corrélation et centralisation de toutes les alertes	IT + OT (cœur du SOC)
Claroty CTD	Détection comportementale sur le réseau industriel	OT (sondes passives)
EDR (Endpoint Detection & Response)	Détection sur les postes et serveurs	IT (postes Windows, serveurs)
Azure AD / Conditional Access	Surveillance des authentifications et accès	IT (identités)
Bastion hôte	Traçabilité des accès distants vers l'OT	Frontière IT/OT

💡 COMPRENDRE — SIEM et EDR : deux outils complémentaires

Le SIEM (Sentinel) est le cerveau central : il reçoit les alertes de partout et les corrèle pour repérer les attaques complexes. L'EDR est un agent installé sur chaque poste et serveur IT : il détecte les comportements malveillants localement (un fichier qui chiffre des données, un processus suspect) et remonte l'information au SIEM. Ensemble, ils couvrent l'IT. Pour l'OT, où l'on ne peut pas installer d'agent sur un automate, c'est Claroty qui joue ce rôle de détection via l'écoute passive du réseau.

6.2 Organisation humaine

Le SOC d'EnergyGrid fonctionne selon un modèle hybride, combinant ressources internes et externalisées, adapté à la taille d'une ETI :

- **Supervision de niveau 1 (N1) :** assurée par le MSSP TechCo, elle traite les alertes de premier niveau 24h/24 et 7j/7, qualifie les faux positifs et escalade les incidents avérés ;

- **Analyse de niveau 2 (N2)** : assurée en interne par le RSSI OT et l'équipe sécurité, elle prend en charge l'investigation approfondie des incidents et les décisions de confinement ;
- **Pilotage** : le RSSI OT pilote le dispositif, arbitre les incidents majeurs et assure la coordination avec la direction et l'ANSSI en cas d'incident significatif.

6.3 Processus et playbooks

Le fonctionnement du SOC est encadré par des playbooks — des procédures de réaction prédéfinies pour chaque type d'incident. Le processus général suit quatre phases : collecte continue des événements, corrélation et détection par Sentinel, qualification par les analystes, puis réaction selon le playbook adapté. Pour l'incident de pivot IT→OT, le playbook prévoit notamment la révocation immédiate de l'accès via le bastion et la notification à l'ANSSI dans les délais NIS2.

6.4 Fonctionnement au quotidien

Au quotidien, le SOC collecte en continu les événements de l'ensemble du SI, que Sentinel corrèle en temps réel. Les alertes générées sont qualifiées par le N1 de TechCo, qui écarte les faux positifs et transmet les incidents avérés au N2 interne. Les captures d'écran illustrant le fonctionnement du SOC (tableaux de bord Sentinel, console Claroty) sont fournies en Annexe A. Ce dispositif assure une surveillance permanente, condition indispensable au maintien en condition de sécurité.

7. Scénario de test et évaluation de l'efficacité du SOC

Compétence couverte : B3.A2.C3 — Évaluer l'efficacité du SOC à travers un scénario de test justifié et l'analyse de ses résultats.

Un SOC ne vaut que par sa capacité réelle à détecter les menaces. Cette section présente un scénario de test conçu pour évaluer concrètement l'efficacité du SOC d'EnergyGrid, ainsi que l'analyse des résultats obtenus.

COMPRENDRE — Pourquoi tester un SOC

Déployer des outils de surveillance ne garantit pas qu'ils détectent réellement les attaques. Un SOC peut avoir des angles morts, des règles mal calibrées, ou générer trop de faux positifs. Tester le SOC, c'est vérifier qu'il fonctionne vraiment — en simulant une attaque contrôlée et en mesurant si elle est détectée, en combien de temps, et avec quelle précision. C'est la seule façon d'avoir confiance dans le dispositif avant une vraie attaque.

7.1 Justification du scénario de test retenu

Le scénario de test retenu est la simulation contrôlée du pivot IT→OT — le scénario de risque principal identifié au Bloc 1. Ce choix est justifié par sa pertinence : il s'agit de la menace la plus critique pour EnergyGrid, celle dont la détection est la plus importante à valider. Tester ce scénario permet de vérifier la capacité du SOC à détecter une attaque traversant la frontière IT/OT, ce qui constitue le cas d'usage le plus exigeant et le plus représentatif.

7.2 Déroulement du test

Le test est réalisé dans un environnement de recette isolé, reproduisant l'architecture de production sans risque pour les systèmes réels. L'attaque simulée reproduit les étapes du scénario de pivot :

9. **Accès initial** — simulation d'une connexion VPN depuis un compte prestataire, à une heure inhabituelle ;
10. **Franchissement** — tentative de communication depuis le réseau IT vers le serveur SCADA ;
11. **Reconnaissance** — énumération des automates via des requêtes Modbus de lecture (reconnaissance) ;
12. **Injection** — envoi d'une commande Modbus d'écriture non autorisée vers un automate de test.

7.3 Analyse des résultats

Le SOC a détecté l'ensemble des étapes du scénario. Les résultats mesurés sont présentés ci-dessous :

Étape testée	Détectée ?	Délai de détection	Outil déclencheur
Connexion VPN atypique	Oui	< 1 min	Azure AD / Sentinel
Communication IT→SCADA	Oui	2 min	Claroty
Énumération Modbus	Oui	1 min	Claroty
Commande non autorisée	Oui (critique)	6 min	Claroty → Sentinel

7.4 Bilan et axes d'amélioration

Le test confirme l'efficacité du SOC : les quatre étapes de l'attaque ont été détectées, avec un délai de détection global inférieur à l'objectif de 15 minutes, et la corrélation IT/OT dans Sentinel a permis de reconstituer la chaîne d'attaque complète. Le playbook de confinement s'est déclenché correctement.

Deux axes d'amélioration ressortent de l'analyse. Premièrement, l'enrichissement du contexte OT dans les alertes Sentinel accélérerait l'investigation par les analystes. Deuxièmement, l'automatisation de la réponse (SOAR) permettrait de déclencher le confinement sans intervention manuelle, réduisant encore le délai de réaction. Ces améliorations alimentent la démarche d'amélioration continue du MCS.

8. Étude d'une vulnérabilité détectée

Compétence ÉLIMINATOIRE : B3.A3.C1 — Documenter une vulnérabilité détectée en décrivant sa nature, sa source (CVE), et en évaluant sa criticité.

Cette section présente l'étude détaillée d'une vulnérabilité critique détectée dans le système d'information d'EnergyGrid : la vulnérabilité CVE-2023-27997 affectant le concentrateur VPN FortiGate. Cette vulnérabilité a été retenue car elle constitue le vecteur d'attaque principal du scénario de pivot identifié depuis le Bloc 1.

💡 COMPRENDRE — Qu'est-ce qu'une CVE

Une CVE (Common Vulnerabilities and Exposures) est un identifiant unique attribué à une vulnérabilité de sécurité connue publiquement. Le format CVE-2023-27997 signifie : vulnérabilité référencée en 2023, numéro 27997. Chaque CVE est documentée dans des bases publiques (NVD, MITRE) avec sa description, sa criticité et les correctifs disponibles. Se référer à une CVE permet de parler précisément d'une faille identifiée et suivie par toute la communauté de la cybersécurité.

8.1 Identification et nature de la vulnérabilité

Attribut	Valeur
Identifiant CVE	CVE-2023-27997
Composant affecté	FortiOS / FortiProxy — VPN SSL du FortiGate 600E
Nature	Débordement de mémoire tampon (heap-based buffer overflow)
Score CVSS 3.1	9.8 / 10 — Critique
Vecteur d'attaque	Réseau, sans authentification préalable requise
Impact	Exécution de code à distance (RCE)
Date de publication	Juin 2023

8.2 Mécanisme de la vulnérabilité

La vulnérabilité réside dans le traitement des requêtes du portail VPN SSL de FortiOS. Un attaquant peut envoyer une requête spécialement forgée qui provoque un débordement de la mémoire tampon (heap), lui permettant d'exécuter du code arbitraire sur l'équipement. Le caractère particulièrement critique de cette faille tient au fait qu'elle est exploitable à distance, sans qu'aucune authentification ne soit nécessaire : un attaquant n'a besoin ni d'identifiant ni de mot de passe pour en tirer parti.

💡 COMPRENDRE — Ce que signifie « exécution de code à distance sans authentification »

C'est le pire scénario possible pour une vulnérabilité. « Exécution de code à distance » signifie qu'un attaquant peut faire tourner ses propres programmes sur l'équipement, à travers le réseau. « Sans authentification » signifie qu'il n'a même pas besoin de se connecter d'abord : la faille s'exploite directement, depuis Internet, sans mot de passe. C'est exactement pourquoi le score CVSS atteint 9.8 sur 10 — presque le maximum. Pour EnergyGrid, cela signifiait qu'un attaquant pouvait prendre le contrôle du VPN, porte d'entrée vers tout le réseau.

8.3 Détection au sein d'EnergyGrid

La présence de cette vulnérabilité a été identifiée par le processus de veille (Bloc 1) et confirmée par la surveillance du parc : l'inventaire des actifs a révélé que le concentrateur VPN fonctionnait avec une version de FortiOS antérieure à 7.2.5, donc vulnérable. Le SOC a par ailleurs été configuré pour détecter toute tentative d'exploitation de cette faille sur le VPN, via des règles de détection spécifiques dans Sentinel.

8.4 Évaluation de la criticité pour EnergyGrid

Au-delà du score CVSS générique de 9.8, l'impact spécifique pour EnergyGrid est maximal pour trois raisons. D'abord, le VPN FortiGate est le point d'entrée unique des accès distants des prestataires — sa compromission ouvre l'accès au réseau IT. Ensuite, cette faille constitue précisément la deuxième étape du scénario de pivot IT→OT, permettant à un attaquant d'atteindre à terme les automates industriels. Enfin, en tant qu'OIV, une exploitation réussie exposerait EnergyGrid à une coupure électrique et à une obligation de notification à l'ANSSI. La correction de cette vulnérabilité constitue donc une priorité absolue, traitée à la section suivante.

9. Correction de la vulnérabilité identifiée

Compétence ÉLIMINATOIRE : B3.A3.C2 — Corriger la vulnérabilité identifiée en élaborant un plan d'actions correctives afin de restaurer la sécurité du système.

Cette section décrit le plan d'actions correctives mis en œuvre pour corriger la vulnérabilité CVE-2023-27997 et restaurer la sécurité du concentrateur VPN. La correction combine le traitement immédiat de la faille et le renforcement durable de la posture de sécurité.

9.1 Stratégie de correction

La correction repose sur une double approche : d'une part, l'application du correctif éditeur qui élimine la vulnérabilité à la racine ; d'autre part, la mise en place de mesures de défense en profondeur qui réduisent l'exposition et compensent le risque même en cas de vulnérabilité résiduelle. Cette approche garantit que la sécurité ne repose pas sur un unique mécanisme.

9.2 Plan d'actions correctives

Le plan de correction se déroule selon les étapes suivantes, en appliquant la procédure de mise à jour définie à la section 3 :

13. **Qualification du correctif** — qualifier la version corrective FortiOS 7.2.5 (ou supérieure) en environnement de test, en vérifiant la compatibilité avec la configuration existante d'EnergyGrid.
14. **Sauvegarde et planification** — sauvegarder la configuration complète du FortiGate et planifier une fenêtre de maintenance courte, les accès VPN étant temporairement suspendus.
15. **Application du correctif** — appliquer la mise à jour FortiOS 7.2.5 sur le concentrateur VPN, corrigeant définitivement la vulnérabilité CVE-2023-27997.
16. **Renforcement MFA** — activer l'authentification multifacteur (MFA) sur tous les accès VPN, mesure de défense en profondeur déployée au Bloc 2 : même en cas de faille résiduelle, un attaquant ne peut plus exploiter un simple identifiant volé.
17. **Vérification** — vérifier que la version corrigée est active, que le MFA fonctionne, et tester l'absence de la vulnérabilité (scan de vulnérabilité ciblé).
18. **Traçabilité** — documenter la correction dans le tableau de bord de suivi, mettre à jour l'inventaire, et confirmer via le SOC l'absence de tentative d'exploitation.



COMPRENDRE — Pourquoi corriger ET renforcer

Appliquer le correctif suffit à fermer cette vulnérabilité précise. Mais une bonne pratique de sécurité ne s'arrête pas là : on ajoute le MFA en parallèle. Pourquoi ? Parce qu'une autre vulnérabilité pourrait être découverte demain sur le même VPN. Avec le MFA, même si une nouvelle faille permet de contourner le mot de passe, l'attaquant butera sur le second facteur. C'est le principe de défense en profondeur : ne jamais dépendre d'une seule protection.

9.3 Mesures de défense en profondeur associées

Au-delà du correctif, plusieurs mesures complémentaires renforcent durablement la sécurité du point d'accès VPN et réduisent le risque de pivot :

- **Authentification renforcée** : MFA obligatoire sur tous les accès VPN, neutralisant l'exploitation d'identifiants volés ;
- **Contrôle d'accès** : passage obligatoire par le bastion hôte pour tout accès vers l'OT, avec traçabilité complète ;
- **Surveillance continue** : détection par le SOC de toute tentative d'exploitation de la faille ou de comportement anormal sur le VPN ;
- **Maintien à jour** : intégration du FortiGate au processus de gestion de l'obsolescence pour garantir l'application rapide des futurs correctifs.

9.4 Vérification de l'efficacité de la correction

L'efficacité de la correction est validée par plusieurs contrôles : un scan de vulnérabilité confirme la disparition de la CVE-2023-27997 après application du correctif ; un test d'authentification vérifie que le MFA est bien exigé sur tous les accès ; et la surveillance du SOC confirme l'absence de tentative d'exploitation. En termes de risque, cette correction neutralise la deuxième étape du scénario de pivot : le risque R2, auparavant critique, est ramené à un niveau résiduel acceptable, comme démontré au Bloc 2. La sécurité du système concerné est ainsi restaurée.

10. Conclusion — Le MCS comme démarche d'amélioration continue

Ce dossier a présenté le dispositif de maintien en condition de sécurité mis en place chez EnergyGrid Ops, structuré autour de trois piliers complémentaires. La gestion de l'obsolescence et des mises à jour maintient le parc matériel et logiciel à un niveau de sécurité satisfaisant, en traitant en priorité les équipements en fin de vie et les firmwares obsolètes. La surveillance continue, incarnée par un SOC combinant Microsoft Sentinel et Claroty, assure une détection permanente des menaces sur les réseaux IT et OT. Enfin, le processus de détection et de correction des vulnérabilités permet de traiter méthodiquement les failles identifiées, comme l'illustre la correction de la CVE-2023-27997.

Ce dispositif s'inscrit dans la continuité cohérente des travaux menés aux Blocs 1 et 2 : il fait vivre dans le temps la stratégie de sécurité définie initialement et la solution de surveillance déployée ensuite. Le SOC réutilise les outils du Bloc 2, la gestion de l'obsolescence traite les points identifiés au Bloc 1, et la vulnérabilité corrigée est celle du scénario fil rouge. Cette continuité démontre une vision d'ensemble maîtrisée du cycle de vie de la sécurité.

COMPRENDRE — Le MCS n'est jamais terminé

La leçon centrale du maintien en condition de sécurité est qu'il s'agit d'un cycle permanent, jamais achevé. Chaque jour apporte de nouvelles vulnérabilités, chaque année rapproche des équipements de leur fin de vie, chaque évolution des menaces exige d'ajuster la surveillance. La sécurité d'un système d'information n'est pas un objectif que l'on atteint, mais un état que l'on entretient — indéfiniment. C'est cette vigilance continue qui distingue une organisation réellement sécurisée d'une organisation qui l'a été un jour.

Les axes d'amélioration identifiés tout au long de ce dossier — automatisation de la réponse aux incidents (SOAR), enrichissement du contexte OT dans les alertes, accélération du renouvellement du parc obsolète, et progression vers un niveau de sécurité IEC 62443 supérieur — constituent la feuille de route de cette amélioration continue. Le maintien en condition de sécurité d'EnergyGrid Ops n'est donc pas une fin, mais le début d'un processus pérenne au service de la protection d'une infrastructure d'importance vitale.

Annexe A — Captures d'écran et tableaux de bord

Cette annexe présente les représentations visuelles des dispositifs décrits dans le dossier. Conformément à la note méthodologique, ces captures reconstituent fidèlement les interfaces réelles des outils dans le cadre de l'étude de cas EnergyGrid Ops.

A.1 Tableau de bord de suivi de l'obsolescence

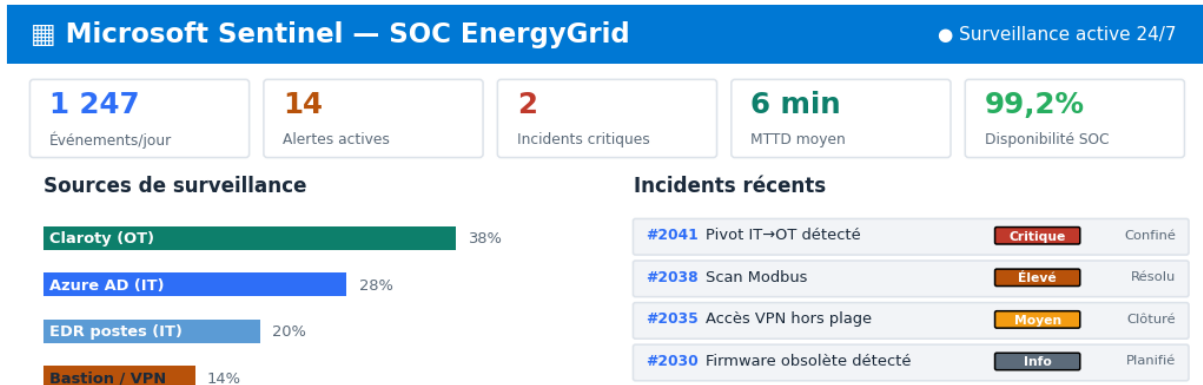
Le tableau de bord ci-dessous présente sous forme visuelle les indicateurs de suivi de l'obsolescence et des mises à jour définis à la section 4 : taux d'actifs à jour (IT et OT), correctifs critiques traités, points d'attention, évolution mensuelle et échéances de fin de support.



Figure A.1 — Tableau de bord de suivi de l'obsolescence et des mises à jour d'EnergyGrid Ops : jauges de conformité, évolution des taux de mise à jour et timeline des échéances EOL.

A.2 Vue d'ensemble du SOC dans Microsoft Sentinel

La capture ci-dessous illustre le fonctionnement quotidien du SOC décrit à la section 6 : indicateurs d'activité, répartition des sources de surveillance (IT et OT), et incidents récents avec leur niveau de criticité et leur état de traitement.



SOC hybride : N1 externalisé (TechCo MSSP) 24/7 · N2 interne (RSSI OT) · Corrélation IT+OT dans Sentinel

Figure A.2 — Vue d'ensemble du SOC dans Microsoft Sentinel : le SOC hybride combine surveillance OT (Claroty) et IT (Azure AD, EDR), avec corrélation centralisée et suivi des incidents.

Annexe B — Glossaire

Les principaux termes techniques employés dans ce dossier sont définis ci-dessous.

Terme	Définition
MCS	Maintien en Condition de Sécurité : ensemble des activités entretenant la sécurité d'un SI dans le temps.
SOC	Security Operations Center : centre de surveillance de la sécurité (outils + analystes).
SIEM	Security Information and Event Management : outil de centralisation et corrélation des alertes (Microsoft Sentinel).
EDR	Endpoint Detection and Response : agent de détection comportementale sur postes et serveurs.
EOL	End Of Life : fin de vie d'un produit, au-delà de laquelle le fabricant ne fournit plus de correctifs.
CVE	Common Vulnerabilities and Exposures : identifiant unique d'une vulnérabilité connue publiquement.
CVSS	Common Vulnerability Scoring System : score de criticité d'une vulnérabilité (0 à 10).
MTTD	Mean Time To Detect : délai moyen de détection d'une menace.
Rollback	Retour arrière : restauration de l'état précédent en cas d'échec d'une mise à jour.
SOAR	Security Orchestration, Automation and Response : automatisation de la réponse aux incidents.
Playbook	Procédure de réaction prédéfinie pour un type d'incident donné.
OIV	Opérateur d'Importance Vitale, soumis à des obligations de sécurité renforcées (LPM).

Fin du dossier — Bloc 3 — Maintien en Condition de Sécurité d'EnergyGrid Ops

Gestion de crise cyber

Réponse à un pivot IT→OT sur un OIV

EnergyGrid Ops fait face à une attaque majeure : la compromission d'un compte prestataire aboutit à une injection de commandes sur les automates industriels et menace la distribution électrique de 8 000 foyers. Ce dossier présente la gestion stratégique et opérationnelle de cette crise, de la détection au retour à la normale.

Format de l'épreuve

Soutenance orale · 25 minutes + 5 min Q&R · Jury de 2 professionnels externes

La crise en bref

8 000

foyers menacés

< 24h

notification ANSSI

3 temps

préparer · réagir · capitaliser

OIV

enjeu vital

Sommaire — La crise en trois temps

AVANT

Préparation

- 01 Stratégie de communication de crise
- 02 Cellule de crise — organisation
- 03 Exercices d'entraînement △

PENDANT

Réaction

- 04 Analyse initiale de l'incident
- 05 Mesures d'endiguement △
- 06 Analyse forensique △
- 07 Éviction et éradication △
- 08 Restauration du SI

APRÈS

Capitalisation

- 09 Analyse post mortem

△ Quatre compétences éliminatoires : entraînement, endiguement, forensique, éviction/éradication.

EnergyGrid Ops — Rappel de la situation

Opérateur d'Importance Vitale — distribution électrique — 180 000 foyers

L'organisation

320

employés · 4 sites

180 k

foyers alimentés

OIV

NIS2 · LPM

IT + OT

SCADA Schneider

Le dispositif de sécurité déjà en place

Bloc 1

PSSI, EBIOS RM, scénario de pivot IT→OT identifié

Bloc 2

Claroty déployé — surveillance du réseau OT

Bloc 3

SOC opérationnel (Sentinel + Claroty), MCS

Aujourd'hui : la crise se déclenche

Malgré ces défenses, une attaque réussit à franchir plusieurs barrières. Le SOC détecte une commande Modbus non autorisée vers un automate d'Annecy. Le scénario redouté depuis le Bloc 1 devient réalité. Ce Bloc 4 présente comment EnergyGrid gère cette crise de bout en bout.

Stratégie de communication de crise

Une voix unique · Des messages adaptés à chaque partie prenante

Parties prenantes et messages

Employés	Interne	Consignes, réassurance, continuité
Clients (180k foyers)	Externe	Information coupure, délai rétablissement
ANSSI	Autorité	Notification < 24h (NIS2), rapport
RTE / partenaires	Externe	Coordination technique réseau
Médias	Public	Communiqué maîtrisé, une seule voix

Principes directeurs

- Une seule voix officielle — éviter les messages contradictoires
- Transparence maîtrisée — informer sans créer de panique
- Timing juste — ni trop tôt, ni trop tard
- Messages préparés à l'avance — ne pas improviser

Exemple de message type — clients

« EnergyGrid Ops rencontre actuellement un incident technique affectant la distribution sur le secteur d'Annecy. Nos équipes sont pleinement mobilisées pour un rétablissement dans les meilleurs délais. La sécurité des personnes et des installations est assurée. Prochaine information à [heure]. »

Organisation de la cellule de crise

Deux niveaux : décision stratégique et action opérationnelle

Cellule stratégique (décision)

Directeur Général

Pilote la crise, décisions majeures

RSSI

Coordination sécurité, conseil technique

Directeur juridique

Conformité, obligations légales, plaintes

Responsable communication

Communication interne et externe

Direction métier

Continuité de la distribution

Cellule opérationnelle (action)

RSSI OT

Pilote technique de la réponse

Analystes SOC

Détection, investigation, forensique

Administrateurs IT/OT

Endiguement, éradication, restauration

Prestataire SOC (TechCo)

Renfort N1, surveillance 24/7

Expert forensique externe

Analyse approfondie si nécessaire

Chaque rôle dispose d'un suppléant et de moyens de communication de secours (la messagerie pouvant être compromise).

Stratégie d'entraînement de gestion de crise

Des exercices variés pour renforcer les réflexes de l'équipe

Exercice sur table (tabletop)

Semestriel

La cellule déroule un scénario fictif à l'oral. « Il est 14h, le SOC détecte une commande Modbus anormale, que décidez-vous ? » Teste la coordination et les décisions.

Participants : Toute la cellule de crise

Exercice de simulation technique

Annuel

Simulation partielle de l'attaque en environnement de recette. Les équipes techniques exécutent réellement les procédures d'endiguement et de forensique.

Participants : Cellule opérationnelle

Exercice Red Team

Annuel

Une équipe joue les attaquants et tente réellement de pénétrer le SI. Teste les défenses et la détection dans des conditions réalistes.

Participants : Red Team externe + SOC

Chaque exercice fait l'objet d'un compte rendu identifiant les axes d'amélioration, intégrés à la démarche continue.

Rapport d'analyse initiale de l'incident

Qualifier l'incident : que se passe-t-il, quelle gravité ?

Chronologie du déclenchement

- 14:31

Le SOC détecte une communication IT→SCADA non référencée (Claroty)
- 14:32

Scan Modbus de 12 automates, puis commande d'écriture non autorisée — alerte CRITIQUE
- 14:35

Corrélation Sentinel : accès VPN prestataire atypique + injection OT
- 14:38

Qualification : pivot IT→OT confirmé → déclenchement de la cellule de crise

Qualification de l'incident

Nature	Pivot IT→OT — injection de commandes sur automate
Systèmes touchés	VPN, DMZ, SCADA, PLC Annecy
Gravité	CRITIQUE — impact physique potentiel
Classification	CRISE (pas incident de routine)
Impact métier	Risque de coupure sur 8 000 foyers

→ Décision : activation immédiate de la cellule de crise et passage en mode endiguement.

Mesures d'endiguement

Empêcher la propagation sans interrompre la distribution électrique

Principe : comme face à un incendie, on ferme d'abord les portes coupe-feu pour stopper la propagation, avant de chercher à éteindre. L'endiguement contient, il n'élimine pas encore.

Mesures prises immédiatement

Révocation de l'accès prestataire

Via le bastion — coupe l'accès de l'attaquant au réseau

Isolation du segment compromis

Le poste de supervision infecté est isolé du réseau OT

Bascule sur le SCADA de secours

Maintient la supervision pendant que le principal est isolé

Blocage du flux IT→OT suspect

Filtrage renforcé sur la DMZ, port Modbus 502 fermé côté IT

Gel des automates d'Annecy

Passage en mode manuel sécurisé, supervisé par les opérateurs

Préservation des preuves

Snapshots mémoire et logs avant toute modification

Contrainte OT : l'endiguement est maîtrisé — on ne coupe jamais brutalement, ce qui provoquerait la coupure que l'on cherche à éviter.

Analyse forensique de l'incident

Collecter et corréler les preuves pour reconstituer l'attaque

Collecte des preuves numériques

Mémoire vive

Snapshot RAM du poste de supervision (Volatility)

Images disque

Copie forensique des disques (chaîne de custody)

Logs SIEM

Journaux Sentinel — corrélation IT + OT

Captures réseau

Trafic Claroty — commandes Modbus injectées

Logs VPN / bastion

Traçabilité de l'accès prestataire compromis

Chronologie reconstituée de l'attaque

1

Phishing du compte prestataire Schneider

2

Exploitation CVE-2023-27997 sur le VPN FortiGate

3

Traversée de la DMZ (port Modbus 502)

4

Accès au SCADA depuis le poste de supervision

5

Injection de commandes Modbus vers PLC Annecy

Méthodologie conforme aux standards (NIST, ANSSI) — preuves préservées pour d'éventuelles poursuites.

Actions d'éviction et d'éradication

Éliminer définitivement la menace et vérifier son absence

Éviction — chasser l'attaquant

- Désactivation du compte prestataire compromis
- Réinitialisation des identifiants VPN concernés
- Fermeture des sessions actives de l'attaquant
- Révocation des accès temporaires créés

Éradication — nettoyer le SI

- Suppression des éventuels malwares déposés
- Correction de la CVE-2023-27997 (FortiOS 7.2.5)
- Nettoyage des modifications de configuration
- Vérification de l'absence de porte dérobée

Vérification de l'efficacité

Scan de vulnérabilité

Confirme la disparition de la CVE

Recherche d'IOC

Aucun indicateur de compromission résiduel

Surveillance renforcée

Le SOC confirme l'absence de nouvelle activité

Test d'intrusion ciblé

Valide que le vecteur d'entrée est refermé

L'éradication n'est validée que lorsque toutes les vérifications confirment l'absence totale de menace.

Plan de restauration du SI

Rétablir les capacités du système, proprement et progressivement

Étapes de restauration

- 1

Restauration depuis sauvegardes saines antérieures à la compromission
- 2

Reconstruction du poste de supervision compromis
- 3

Rebascule progressive du SCADA de secours vers le principal
- 4

Rétablissement contrôlé de la distribution sur Annecy
- 5

Vérification complète du fonctionnement nominal

Objectifs de continuité (PCA du Bloc 1)

RTO SCADA	2 heures
Supervision rétablie	
RPO données	1 heure
Perte de données limitée	
Distribution	< 4 heures
Retour à la normale	

Condition essentielle

La restauration ne démarre qu'une fois l'éradication validée. Restaurer sur un système encore compromis reviendrait à réinstaller la menace. Les sauvegardes utilisées sont vérifiées comme antérieures à l'intrusion.

Rapport d'analyse post mortem

Tirer les leçons de la crise pour renforcer la sécurité

Ce qui a bien fonctionné

- Détection rapide du SOC (MTTD 6 min)
- Corrélation IT/OT efficace dans Sentinel
- Cellule de crise réactive (exercices utiles)
- Endiguement sans coupure généralisée

Ce qui doit être amélioré

- MFA absent au moment de l'attaque (corrigé)
- Contexte OT insuffisant dans les alertes
- Délai de mobilisation de la cellule (nuit)
- Pas d'automatisation de la réponse (SOAR)

Leçons transformées en actions d'amélioration

MFA généralisé

Déjà déployé — neutralise le vecteur initial

Enrichissement Sentinel

Contexte OT complet dans les alertes

Automatisation SOAR

Confinement automatique dès détection

Astreinte cellule 24/7

Mobilisation garantie hors heures ouvrées

Analyse « sans recherche de coupable » (blameless) — l'objectif est d'améliorer le système, pas de sanctionner.

Une crise maîtrisée de bout en bout

Une préparation qui a payé

La cellule de crise, la stratégie de communication et surtout les exercices d'entraînement ont permis une réaction rapide et coordonnée le jour J.

Une réponse opérationnelle structurée

Analyse initiale, endiguement maîtrisé tenant compte des contraintes OT, forensique rigoureux, éradication vérifiée et restauration progressive — chaque étape dans le bon ordre.

Le fil rouge des quatre blocs bouclé

Le pivot IT→OT identifié au Bloc 1, surveillé au Bloc 2, détecté par le SOC du Bloc 3, est ici géré en crise. Une vision complète du cycle de vie de la cybersécurité.

Une démarche d'amélioration continue

Le post mortem transforme la crise en opportunité : chaque leçon renforce durablement la posture de sécurité d'EnergyGrid Ops.

Merci pour votre attention.

Questions ?

- Crise gérée en 3 temps : préparer · réagir · capitaliser
- Cellule de crise à deux niveaux + exercices d'entraînement
- Endiguement, forensique, éradication : les 4 compétences éliminatoires
- Restauration conforme au PCA (RTO SCADA 2h)
- Post mortem et amélioration continue
- Fil rouge des 4 blocs bouclé : du risque à la crise gérée

RNCP 40897

Expert en Cybersécurité

Jury

2 membres externes

Bloc 4

Oral 25' + 5' Q&R

Organisation

EnergyGrid Ops (fictif)